

PIEDPIN

Let's try CISSP!

なぜCISSPを学ぶのか

- ✓ CISSP(Certified Information Systems Security Professional)とは、世界標準の**セキュリティ・プロフェッショナル認定**です。
- ✓ (ISC)²（国際情報システムセキュリティ認証コンソーシアム、International Information Systems Security Certification Consortium）が認定を行っています。
- ✓ 情報セキュリティ専門家が共通言語として利用している『(ISC)² CISSP CBK』を理解している者に与えられる資格です。
- ✓ 2004年6月に、米国規格協会（ANSI）より**ISO/IEC17024**の認証を受け、信頼度がより高くなりました。（https://japan.isc2.org/cissp_about.html）
- ✓ 2022年7月1日現在、日本のCISSPは**3,699**人です。

(ISC)² が展開する資格ソリューション



国際的に認められた情報セキュリティ・プロフェッショナル認定資格です。米国規格協会（ANSI）よりISO/IEC17024の認証を受けた。



ベンダーフリー・カントリーフリーの情報セキュリティの資格です。情報セキュリティに従事しないが、組織を理解し、適切なコミュニケーションを行う。



クラウドサービスを安全に利用するために必要な知識を体系化した資格です。



ソフトウェアの脆弱性に端を発したセキュリティインシデントの増加や、政府や重要インフラにおけるセキュアなソフトウェアニーズに対応する資格です。

(ISC)² CISSP CBK ドメイン



ドメイン 1
セキュリティとリスク
マネジメント



ドメイン 2
資産のセキュリティ



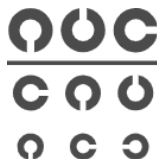
ドメイン 3
セキュリティアーキ
テクチャとエンジニ
アリング



ドメイン 4
通信とネットワー
クのセキュリティ



ドメイン 5
アイデンティティと
アクセスの管理



ドメイン 6
セキュリティの評
価とテスト



ドメイン 7
セキュリティの運用



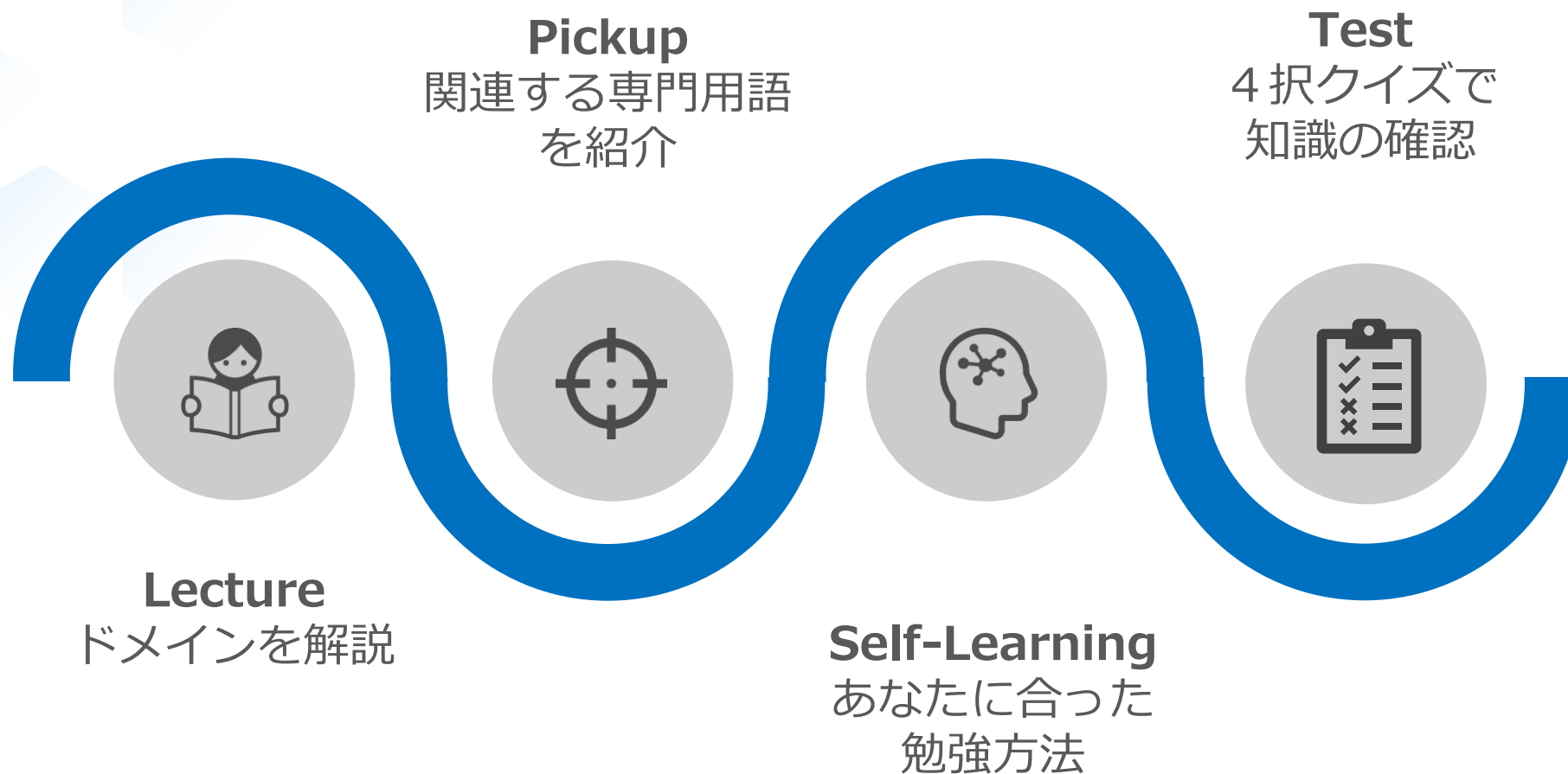
ドメイン 8
ソフトウェア開発
セキュリティ

あなたのゴールと本レッスンの内容

- ✓ 情報セキュリティ初心者のために設計されたCISSP講座
経験者からすると“当たり前”と感じる内容も含まれます。
- ✓ 本レッスンの対象は、CBKのドメイン 4 です。
他のドメインのレッスンは対象外となります。
- ✓ CISSP合格のためのアップグレードが必要です。
現代のセキュリティの関心、流行、考え方を織り込みます。



レッスンの流れ



ドメイン別試験比重



ドメイン 1
セキュリティと
リスクマネジメント

16%



ドメイン 2
資産のセキュリティ

10%



ドメイン 3
セキュリティアーキテク
チャとエンジニアリング

13%



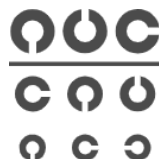
ドメイン 4
通信とネットワーク
のセキュリティ

13%



ドメイン 5
アイデンティティと
アクセスの管理

13%



ドメイン 6
セキュリティの評価
とテスト

12%



ドメイン 7
セキュリティの運用

13%



ドメイン 8
ソフトウェア開発
セキュリティ

10%



ネットワークアーキテクチャ

ネットワークアーキテクチャ

ネットワーク

● 送受信の方法

通信の際には、送信端末と受信端末が存在します。端末間の目的によっては通信の方向が区分されます。

用語	定義	例
単方向通信 (Simplex Communication)	一方向のみの通信。	ラジオ放送、テレビ放送
半二重通信 (Half-Duplex Communication)	双方向通信が可能だが、交互にしか通信できない。	トランシーバー、無線の交信
全二重通信 (Full-Duplex Communication)	同時に双方向で通信できる。	電話、インターネット通信



単方向通信



半二重通信



全二重通信

ネットワークアーキテクチャ

ネットワーク

● 規模によるネットワーク分類

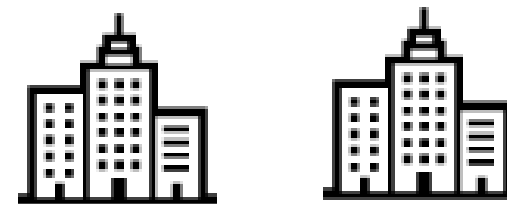
通信端末（ノード）と各端末通信から成るものをネットワークと言います。ネットワークは、規模に応じて区分する用語が存在します。

用語	定義	例
PAN (Personal Area Networks)	個人のデバイス間	Bluetooth、赤外線通信、USB接続
LAN (Local Area Networks)	特定の建物やオフィス、学校	イーサネット、Wi-Fi
MAN (Metropolitan Area Networks)	都市規模	都市規模のインターネットプロバイダ
WAN (Wide Area Networks)	国や大陸、複数の都市	インターネット、企業のグローバルネットワーク
GAN (Global Area Networks)	地球規模	インターネット、衛星通信ネットワーク

WAN/
GAN



MAN



LAN



PAN



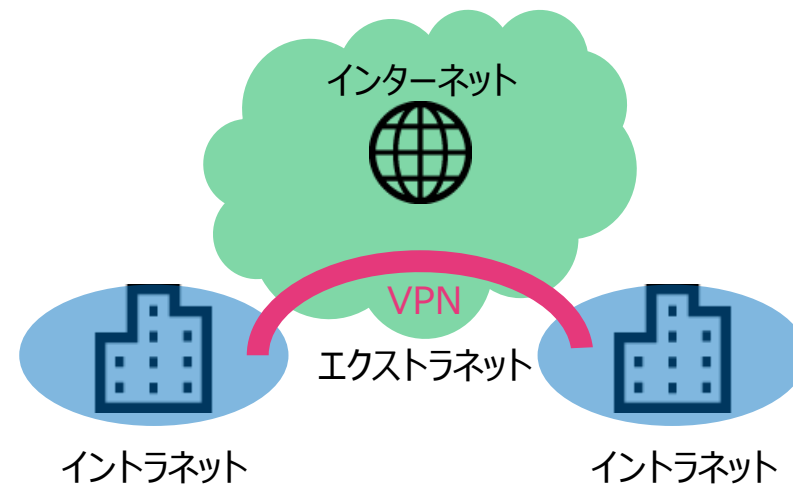
ネットワークアーキテクチャ

ネットワーク

● 所有によるネットワーク分類

ネットワークは、自身でネットワーク機器を購入し構築することもあります。オープンに張り巡らされたネットワークを利用する場合もあります。

用語	定義
インターネット (Internet)	公開された世界中の誰でもアクセス可能なネットワーク。
イントラネット (Intranet)	企業や組織内で使用されるプライベートなネットワークで、外部アクセスは制限される。
エクストラネット (Extranet)	イントラネットを外部の特定の関係者に対して拡張したネットワークで、アクセスは信頼された外部者に限定される。



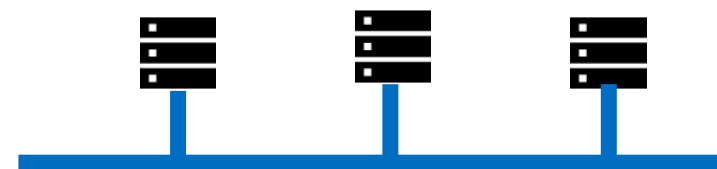
ネットワークアーキテクチャ

トランスポートアーキテクチャ

● ネットワークトポロジー

バス型

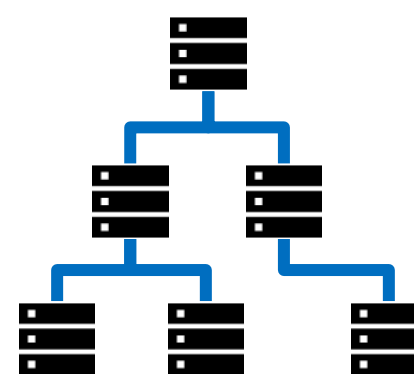
- ・ 一つのケーブルに複数のノードを接続するトポロジーです。
- ・ ケーブルが一つしかないため、ケーブルが断線などすれば、全体が通信できなくなります。



バス型

ツリー型

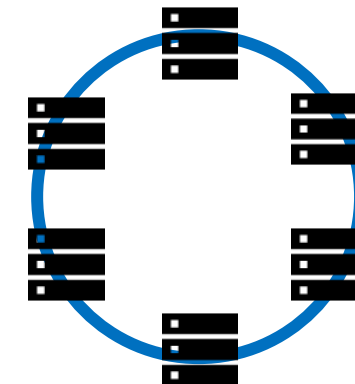
- ・ 階層型ネットワークとも呼ばれます。最上位のノードから子ノードを広げていきます。



ツリー型

リング型

- ・ リング状にノードを接続します。ノードからノードへのケーブルをたどるように通信します。



リング型

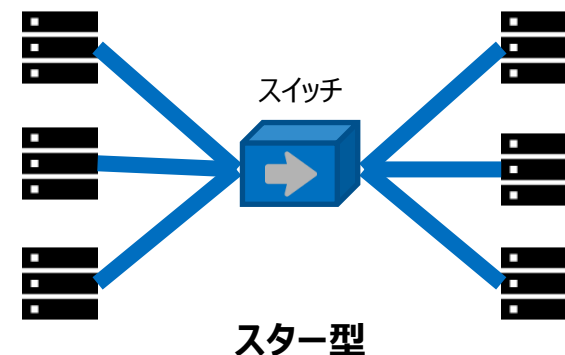
ネットワークアーキテクチャ

トランスポートアーキテクチャ

● ネットワークトポロジー

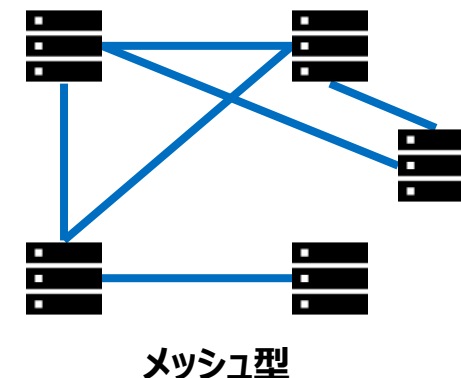
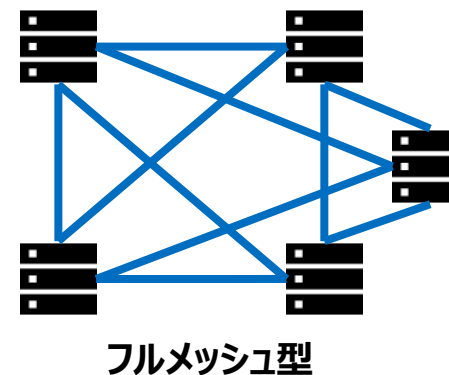
スター型

- 各ノードはハブやスイッチなどの中央デバイスに直接接続されます。
- 一つのローカルケーブル切断しても、接続されているノードのみ接続できなくなるだけで、全体には影響が出ません。
- 最初にARCNETによって普及し、後にイーサネットによって採用されました。



メッシュ型

- 通信端末同士で網のように、通信し合っているネットワーク構成です。
- すべての通信端末が他のすべての通信端末と接続されている構成をフルメッシュと言い、部分的に双方向通信を行っている構成を純粋にメッシュ型と言います。



ネットワークアーキテクチャ

トランスポートアーキテクチャ

● ネットワークトポロジー

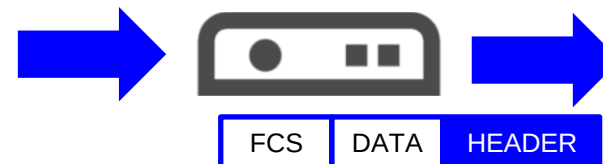
スイッチなどはネットワーク端末には通信の中継を行います。

Cut Through

- 受信したデータパケットの一部だけを読み取った段階で即座に転送を開始する方式です。
- データフレームの先頭部分を受信した段階で、送信先が決定されるとすぐに転送を開始します。

Store and Forward

- データパケットを完全に受信してから、エラーチェックを行い、正しいことが確認できた後に転送する方式です。



Cut ThroughではFCSを待ちません。



Store and ForwardではFCSにてエラーチェックを行ってからHEADERを送信する

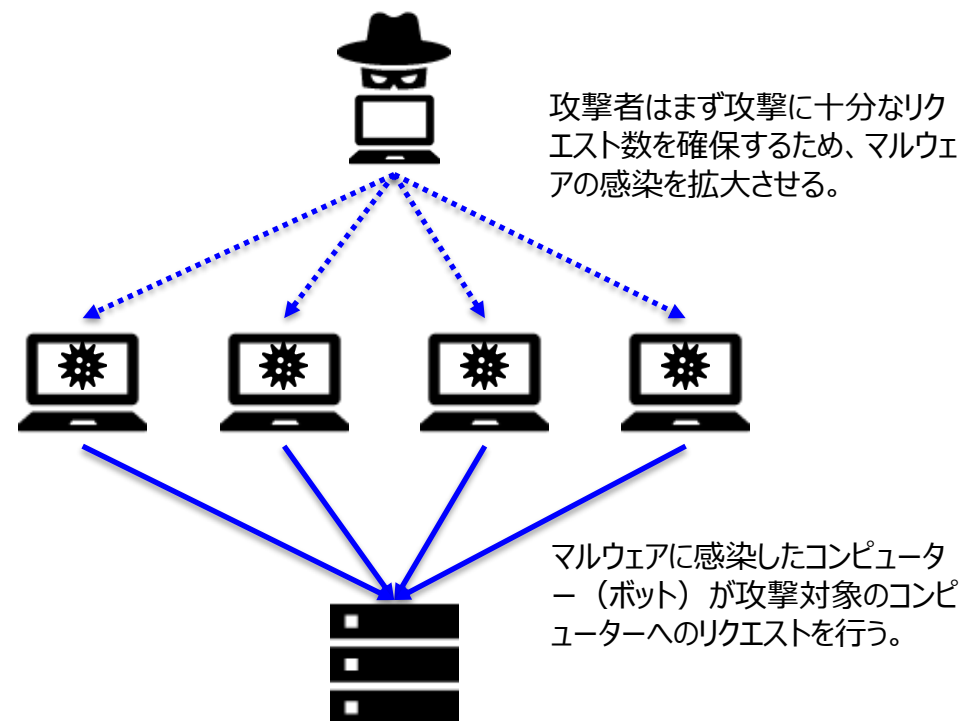
ネットワークアーキテクチャ

トランスポートアーキテクチャ

● ネットワーク障害

サービス拒否攻撃、DoS攻撃 (Denial of Service)

- 稼働しているサーバーやネットワーク機器に対して、大量のリクエストを送付することでリソースに意図的に過剰な負荷をかける攻撃です。
- 分散型サービス拒否攻撃、DDoS攻撃 (Distributed Denial of Service attack) とは、あらゆる端末から一つのターゲットに対して攻撃を行うことです。
- クラウドサービスが基本的に従量課金制であることから、アクセスを負荷をかけ、経済的な負担を負わせようとする攻撃もあります。



ネットワークアーキテクチャ

トラフィックフロー

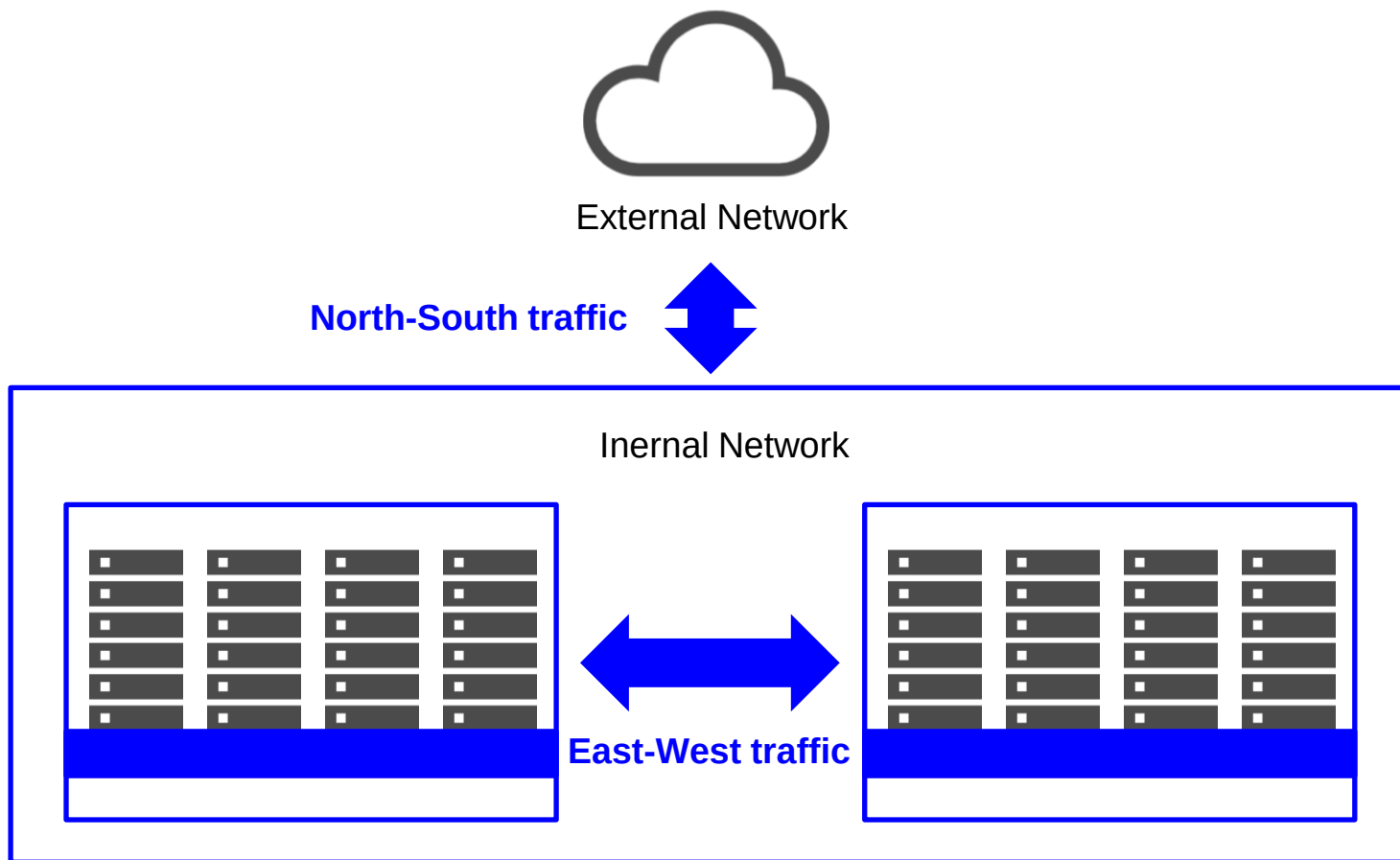
●トラフィックフロー

East-West traffic (東西トラフィック)

- 同じデータセンター内や同じネットワーク内での、サーバー間、またはデバイス間のデータの流れを指します。

North-South traffic (南北トラフィック)

- ネットワーク外部とのデータのやり取り、つまりクライアントや他のデータセンター、インターネットとの通信を指します。

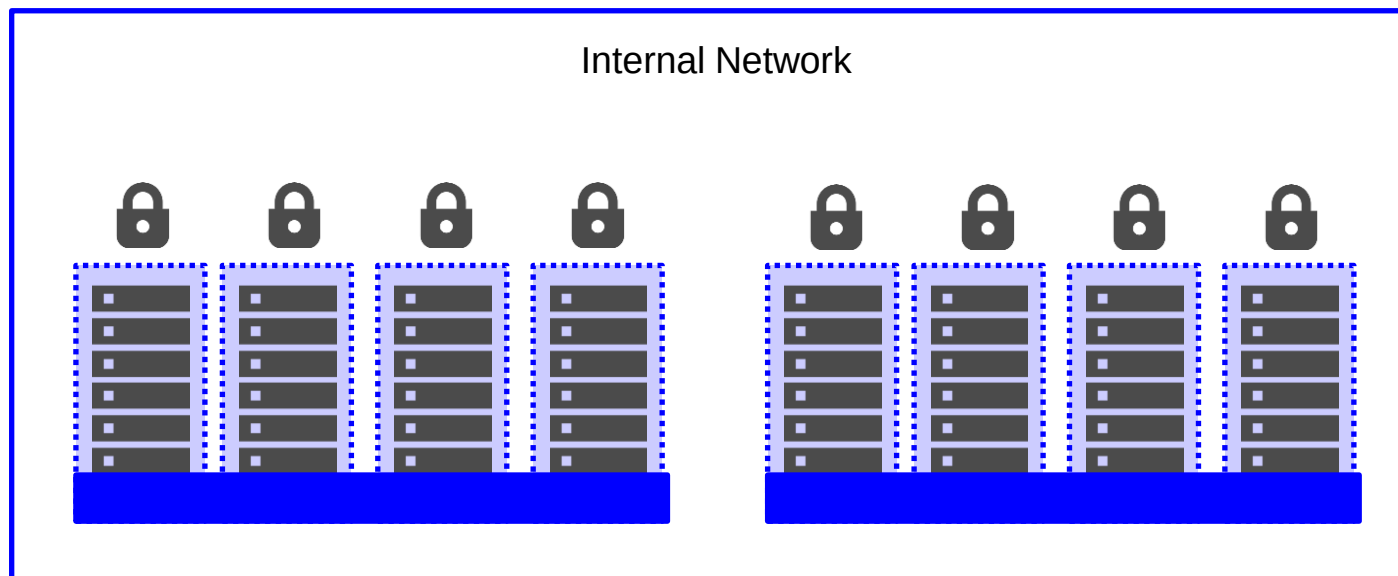


ネットワークアーキテクチャ

セグメンテーション

● マイクロセグメンテーション (micro-segmentation)

- データセンターやクラウド環境内のセキュリティ戦略の一つです。ネットワークを細かく分割し、各セグメントごとに個別のセキュリティポリシーを適用する技術です。
- Internal Network内でもホスト毎、端末間は外部と通信を保護します。
- この仕組みは、ゼロトラストから派生したものです。ゼロトラストは「何も信頼しない」ことを前提にしたセキュリティモデルで、すべての通信やリソースへのアクセスを検証する仕組みです。





ネットワークプロトコル

ネットワークプロトコル

OSI参照モデルとTCP/IPモデル

●OSI（Open Systems Interconnection）参照モデル

階層		内容	主なプロトコル
7	アプリケーション層 (Application Layer)	ユーザーやアプリケーションが直接通信する層です。	HTTP、FTP、SMTP、DNS
6	プレゼンテーション層 (Presentation Layer)	データの形式や表現方法を定義し、異なるシステム間でデータが正しく解釈されるようにします。	JPEG、PNG、SSL/TLS
5	セッション層 (Session Layer)	通信のセッションを管理し、開始、維持、終了を行います。	NetBIOS、PPTP
4	トランスポート層 (Transport Layer)	データの信頼性やエラー修正、フロー制御を提供します。	TCP、UDP
3	ネットワーク層 (Network Layer)	異なるネットワーク間のルーティングやアドレス指定を担当し、パケット（データ）の中継を行います。	IP、ICMP、ARP、OSPF
2	データリンク層 (Data Link Layer)	隣接するデバイス間でのフレーム転送を行います。	Ethernet、PPP、HDLC
1	物理層 (Physical Layer)	実際にデータが物理的な形で送受信される層です。	光ファイバー、銅線、無線周波数、Bluetooth

ネットワークプロトコル

OSI参照モデルとTCP/IPモデル

●TCP/IPモデル

- OSI参照モデルは教育や概念理解のために使われ、TCP/IPモデルは現実のインターネット通信で使われています。

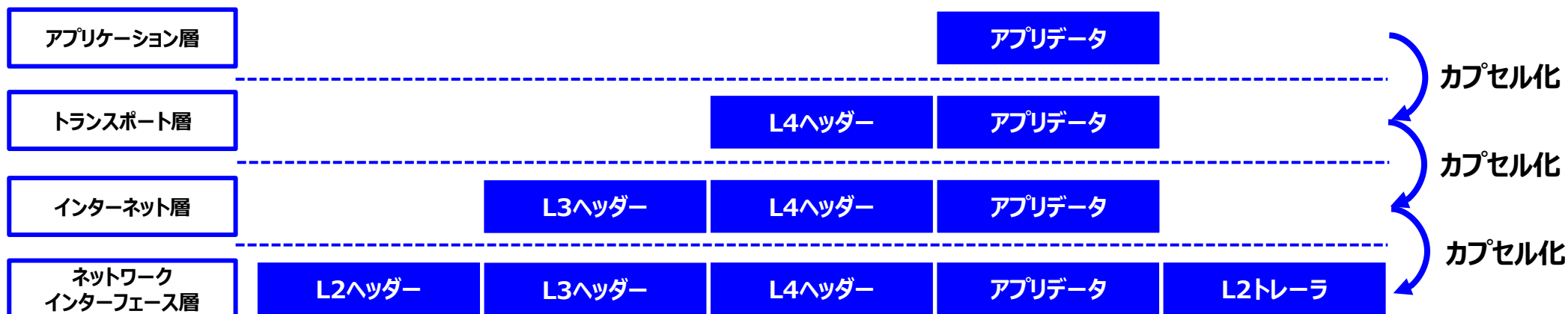
階層	OSI参照モデル	TCP/IPモデル	通信データの呼び名
7	アプリケーション	アプリケーション	アプリデータ
6	プレゼンテーション		
5	セッション		
4	トランスポート	トランスポート	セグメント
3	ネットワーク	インターネット	パケット
2	データリンク	ネットワークインターフェース	フレーム
1	物理		ビット

ネットワークプロトコル

OSI参照モデルとTCP/IPモデル

●カプセル化 (encapsulate)

- カプセル化とは、アプリケーションで扱うデータを通信データとして使えるようにするための方法です。
- ネットワークモデルでは、階層型で示されるように実際のデータも上位層から情報を取得し、下層の制御情報をヘッダーとして追加します。送信側から通信データを生成するため、下層の通信ヘッダーを付与していきます。
- 反対に、受信側は上層に通信ヘッダーを解釈していきます。これをデカプセル化 (decapsulation) と言います。



ネットワークプロトコル

アドレス

●MACアドレス (Media Access Control Address)

- ネットワークインターフェイスカード (NIC、Network Interface Card) の一意に振られているデータリンク層のアドレスです。
- MACアドレスは、データリンク層の通信端末の伝送のために利用されます。
- MACアドレスは48ビット長から構成され、前半24ビットはOUI (Organizationally Unique Identifier) と呼ばれるメーカーの識別番号、後半24ビットは各メーカーが一意に割り当てた番号です。

11-22-33-44-55-66

第1オクテット 第2オクテット 第3オクテット 第4オクテット 第5オクテット 第6オクテット

OUI

ベンダー管理番号

ネットワーク インターフェース層		インターネット層		トランスポート層		アプリケーション層	
MACアドレス		IPアドレス		ポート番号		データ	
宛先	送信元	宛先	送信元	宛先	送信元		

ネットワークプロトコル

アドレス

●IPアドレス (Internet Protocol Address)

IPv4 (Internet Protocol Address version 4)

- 1970年代に米国国防高等研究計画局（DARPA）のパケット交換ネットワークをサポートするために設計されました。

IPv6 (Internet Protocol Address version 6)

- IPv6はMACアドレスよりも多くのアドレスを扱えるため、MACアドレスからIP用のアドレスを生成する技術オートコンフィグレーションを持ち、製品製造時点で発番されたアドレスを参考とするため、矛盾なく不要な設計が必要がありません。

ネットワーク インターフェース層		インターネット層		トランスポート層		アプリケーション層
MACアドレス		IPアドレス		ポート番号		データ
宛先	送信元	宛先	送信元	宛先	送信元	



IPv4のパケットフォーマット



IPv6のパケットフォーマット

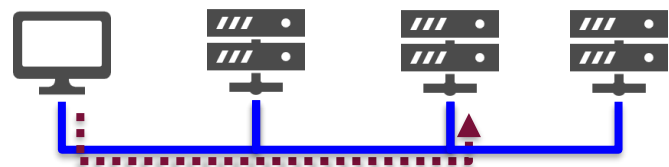
ネットワークプロトコル

アドレス

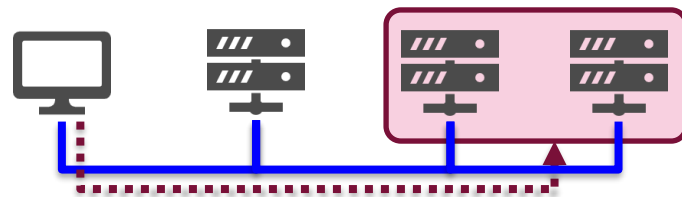
●ユニキャスト／マルチキャスト／ブロードキャスト

項目	内容	主なプロトコル
ユニキャスト (Unicast)	1対1の通信方式です。送信元が1つのデバイスに対して直接データを送信します。	HTTP通信、SSH接続、ファイル転送(FTP)、メール
マルチキャスト (Multicast)	1対多の通信方式です。送信元から特定のグループに属する複数の受信者に同時にデータを送信します。	ビデオ会議、ライブストリーミング、IPTV(インターネットテレビ)、ルーティングプロトコル(OSPF, RIP)
ブロードキャスト (Broadcast)	1対全の通信方式です。送信元がネットワーク内のすべてのデバイスにデータを送信します。	ARPリクエスト(MACアドレスを問い合わせる際)、DHCP(IPアドレスの取得)、ローカルネットワーク内の探索通信

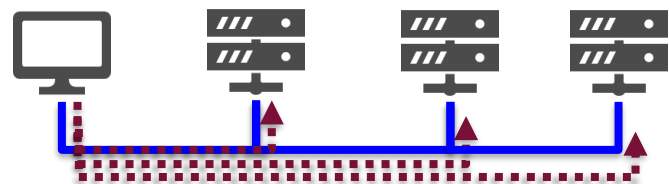
ユニキャスト



マルチキャスト



ブロードキャスト



ネットワークプロトコル

アドレス

●IPアドレスのクラス化（RFC1918）

クラスフルネットワーク

- IPアドレスは、ネットワーク規模に合わせて利用するIPアドレスを指定されています。

クラス	先頭ビット列	アドレス範囲	割り当て可能な ホスト数	プライベートアドレス	通信体系
クラスA	0	0.0.0.0～ 127.255.255.255	16777214個	10.0.0.0/8	ユニキャスト
クラスB	10	128.0.0.0～ 191.255.255.255	65534個	172.16.0.0/16	
クラスC	110	192.0.0.0～ 223.255.255.255	254個	192.168.0.0/24	
クラスD	1110	224.0.0.0～ 239.255.255.255	-	-	マルチキャスト
クラスE	1111	240.0.0.0～ 255.255.255.255	-	-	予約済み

ネットワークプロトコル

アドレス

●IPアドレスのクラス化（RFC1918）

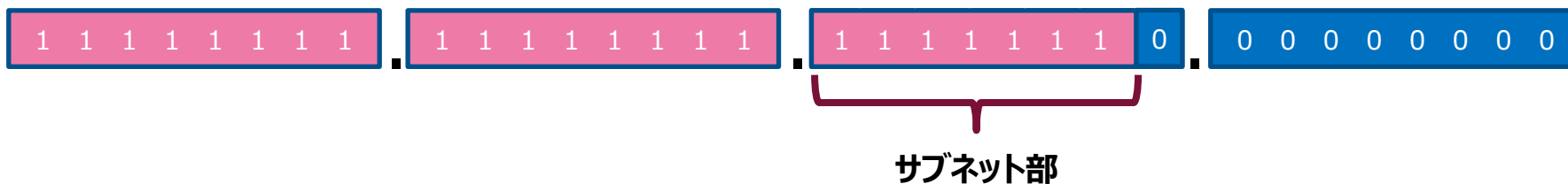
クラスレスネットワーク

- CIDR（Classless Inter-Domain Routing）とは、ホスト部のビットの一部をネットワーク部にすることでより多くのネットワークを構成することが可能にするため、クラスフルネットワークにサブネットで細分化する方法です。
- クラスフルネットワークでは、実際ネットワークの数は限られているため、ネットワークの区分ルールをベースとして自ネットワークを構成する目的です。

クラスBのネットワークマスク（255.255.0.0）



クラスBのネットワークマスク（255.255.0.0）をサブネットで細分化



ネットワークプロトコル

アドレス

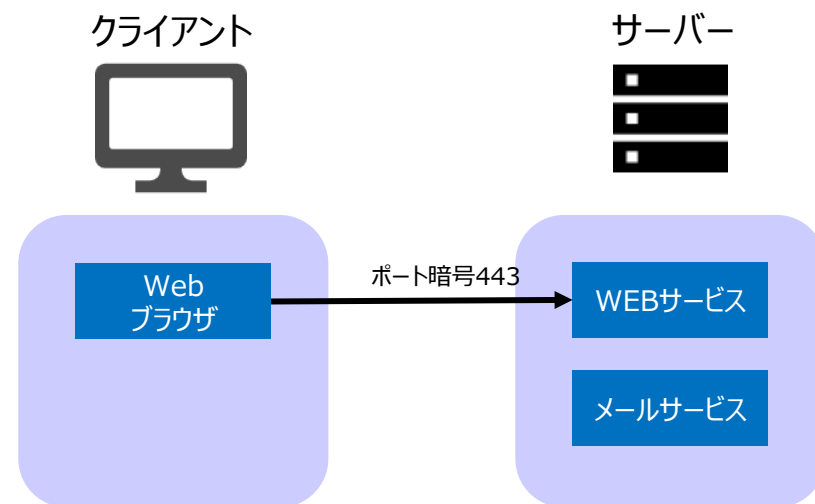
●ポート番号

- ウェルノウンポート番号 (0-1023)とは、IANAで正式に登録されているポート番号です。
- 登録済みポート番号 (1024-49151)とは、IANAで正式に登録されているポート番号です。
- 動的・プライベート ポート番号 (49152-65535)とは、IANAで正式に登録されていないポート番号です。

●ソケットペア

- IPアドレスとポート番号の組み合わせのことです。

ネットワーク インターフェース層		インターネット層		トランスポート層		アプリケーション層
MACアドレス		IPアドレス		ポート番号		データ
宛先	送信元	宛先	送信元	宛先	送信元	



ポート番号とサービス利用

ネットワークプロトコル

アドレス

●ネットワークアドレス変換（NAT、Network Address Translation）

静的NAT（Static NAT）

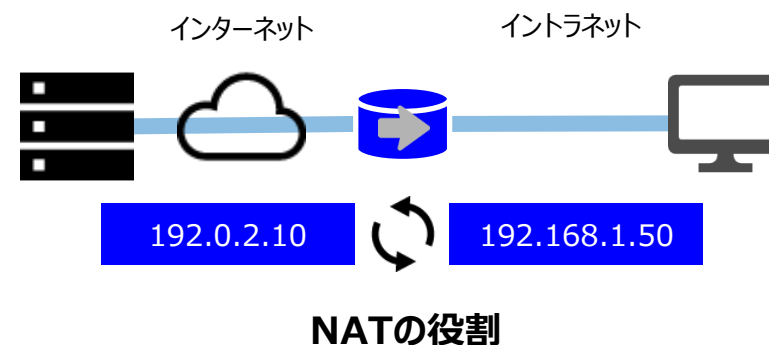
- プライベートアドレスとパブリックアドレスを1対1の変換を行います。

動的NAT（Dynamic NAT）

- パブリックアドレスをいくつかプールしておき、利用する際に適宜割り当てられます。

ポートアドレス変換（Port Address Translation）

- 複数のプライベートアドレスから1つのパブリックアドレスに変換します。
- PATは利用しているプライベートアドレスとサービスポートの組み合わせとパブリックアドレスをキャッシュします。



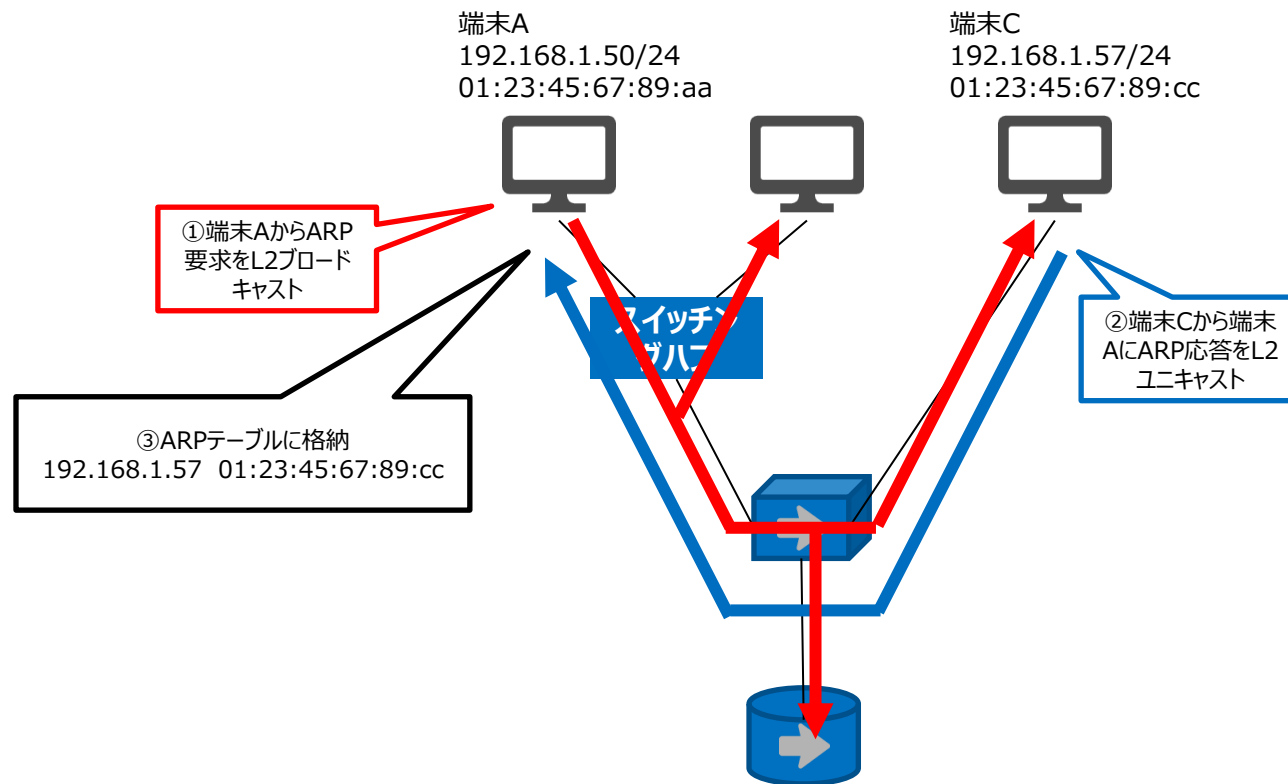
NATの種類	例
静的NAT	192.168.1.50 → 192.0.2.10
動的NAT	192.168.1.50 → 192.0.2.10 192.168.1.55 → 192.0.2.11 192.168.1.57 → 192.0.2.12
PAT	192.168.1.* → 192.0.2.10

ネットワークプロトコル

アドレス

●ARP (Address Resolution Protocol) 、RARP (Reverse Address Resolution Protocol)

- ARPは、レイヤー2のMACアドレスとレイヤー3のIPアドレスの間の変換するためのアドレス解決プロトコルです。
- ARP要求をL2ブロードキャストを行い、同一ネットワーク上の端末を行います。該当の端末は、ユニキャストでARP応答を行います。これにより、IPアドレスとMACアドレスを紐づけることができ、端末はテーブルに格納することで、今後のARP要求を省略します。
- 逆にMACアドレスからIPアドレスを答えるプロトコルをRARPと呼びます。



ARPによるIPアドレスとのマッピング

ネットワークプロトコル

インターネットプロトコル

● ICMP (Internet Control Message Protocol)

- レイヤー 3 の通信プロトコルです。シーケンス制御がありません。
- 接続ダウン時に、どのサーバーやルーターが障害を起こしているのかを特定することが可能です。
- 「ping」コマンド、「traceroute」コマンドで実行することができます。

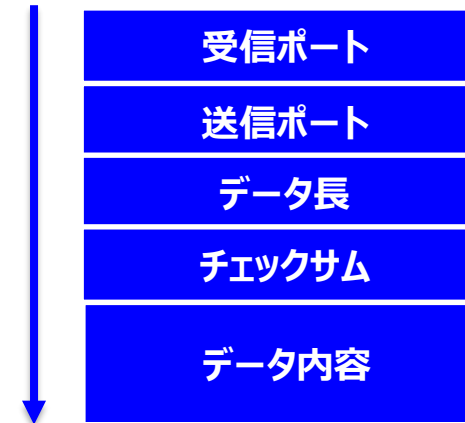
● UDP (User Datagram Protocol)

- レイヤー 4 の通信プロトコルです。
- 送信してもその通信が相手に届いていることを保証しません。
- TCPと比べ高速であるため、ある程度は劣化しても良いデータ音楽のストリーミングに利用されます。

ICMPのパケット構造



UDPのパケット構造



ネットワークプロトコル

インターネットプロトコル

●TCP (Transmission Control Protocol)

- レイヤー 3 の通信プロトコルです。
- TCPスリーウェイハンドシェイクを使用して、ネットワーク全体に信頼性の高い接続を作成します。
- TCP接続した場合、分散して到着したセグメントを並べ替えたり、欠落しているセグメントを再送信できます。
- **TCPフラグ**とは、各TCPパケットのTCPヘッダ内の6ビットのフィールドであり、パケット内容を示します。

TCPのパケット構造

受信ポート
送信ポート
シーケンス番号
確認応答番号
データオフセット
予約済み
フラグ
ウィンドウ
チェックサム
緊急ポインター
オプション
パディング
データ内容

フラグ	意味
URG	パケットに緊急データが含まれている
ACK	受信データを確認
PSH	アプリケーションレイヤーにデータをプッシュ
RST	接続をリセット
SYN	接続を同期
FIN	正常に接続を終了
CWR	輻輳ウィンドウ削減
ECE	明示的な輻輳通知エコー
NS	輻輳を管理

ネットワークプロトコル

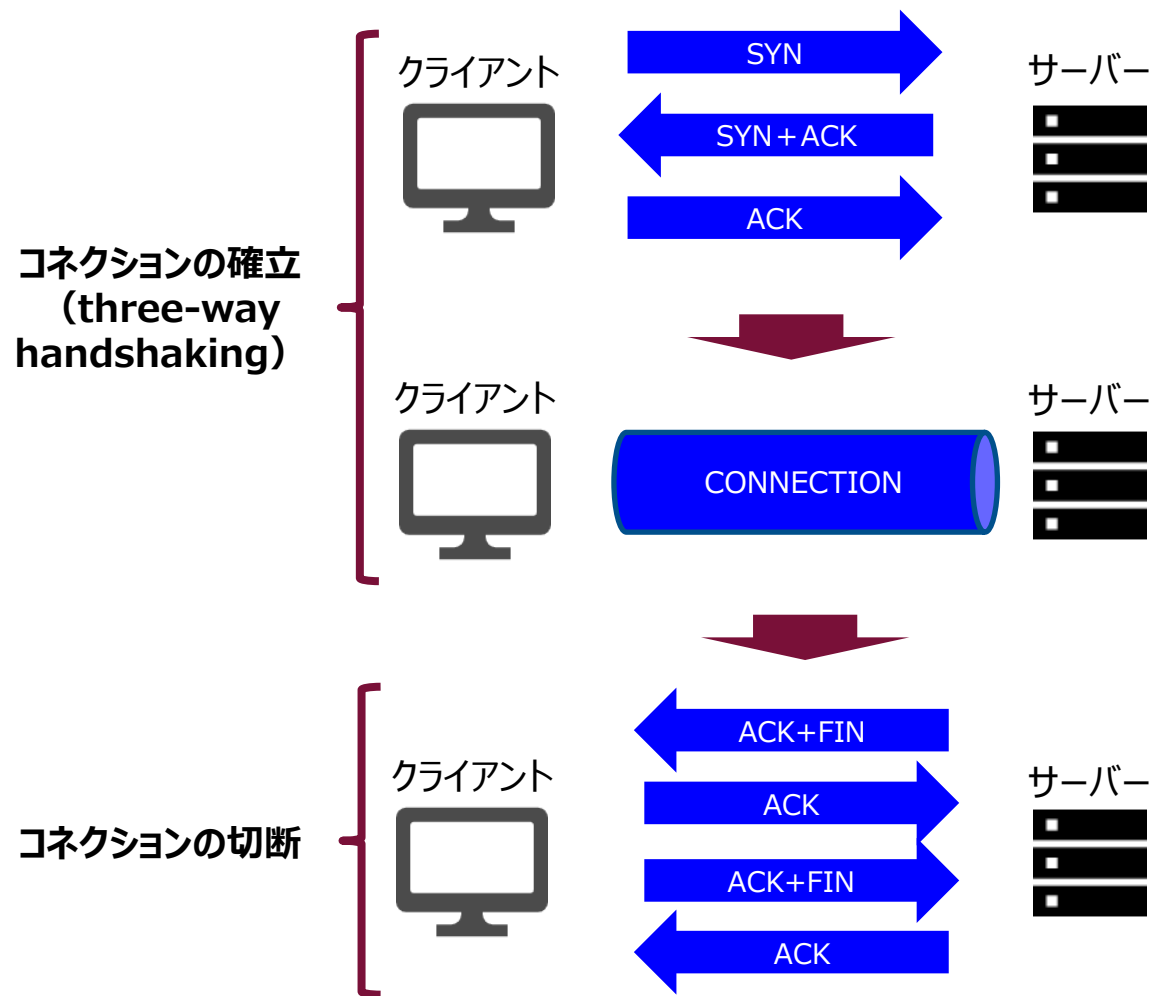
インターネットプロトコル

●TCP (Transmission Control Protocol)

Three-way handshaking

- ① クライアントがランダムに決めたシーケンス番号を付与したSYNパケットを送る。
- ② サーバーは受け取ったシーケンス番号と1を加えたACK番号を付与したSYN+ACKパケットを返信する。
- ③ クライアントが受け取ったシーケンス番号に1を加えたものとACK番号を付与したACKパケットを送信することで接続の確立する。

- 確立された接続は、最終的にRST（接続をリセットまたは切断）またはFIN（接続を正常に終了）で終了します。



ネットワークプロトコル

インターネットプロトコル

●TCPを利用した攻撃

Smurf攻撃

- DoS攻撃の一種であり、攻撃対象となる通信機器のIPアドレスを送信元アドレスに偽装し、大量のICMPパケットをブロードキャストで送信する攻撃です。

Teardrop

- IPパケットの分割前に戻すときのオフセットを偽造することでシステムを停止させる攻撃です。
- 一つのパケットで送付できない程の大きなデータである場合、順列のオフセット番号を付与してから送付し、受信側で組み立てます。
- 通常では想定されていないパケットを送付することで制御系を狙う攻撃の一種であり、オフセット番号を他のパケットと重複するように偽装し、受け取り側を停止させます。

受信ポート
送信ポート
シーケンス番号
確認応答番号
データオフセット
予約済み
フラグ
ウィンドウ
チェックサム
緊急ポインター
オプション
パディング
データ内容

分割された送られたパケット内容の順番通りに直す

ネットワークプロトコル

インターネットプロトコル

●TCPを利用した攻撃

Christmas tree attack

- TCPパケットにいくつかのTCPフラグ（URG、ACK、PSH、RST、SYN、FIN）を立てて送り、応答を観察する攻撃です。
- 確認パケットでは部分的にフラグを付け替えることでネットワーク機器の動作を確認します。すべてのフラグを立てているにも関わらず、受け取り手の異なる反応をすると、サービスが停止しているなど他と何か違うことが判断できます。

受信ポート
送信ポート
シーケンス番号
確認応答番号
データオフセット
予約済み
フラグ
ウィンドウ
チェックサム
緊急ポインター
オプション
パディング
データ内容

通信状態を管理

ネットワークプロトコル

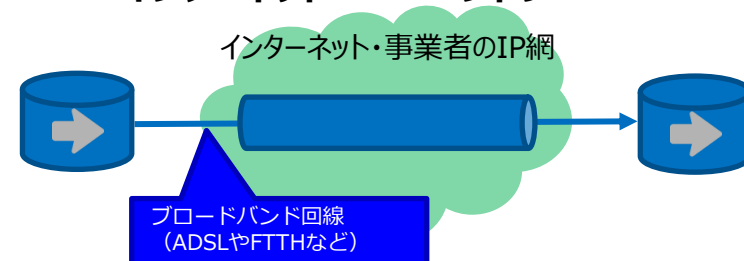
セキュアプロトコル

● 仮想プライベートネットワーク (Virtual Private Network)

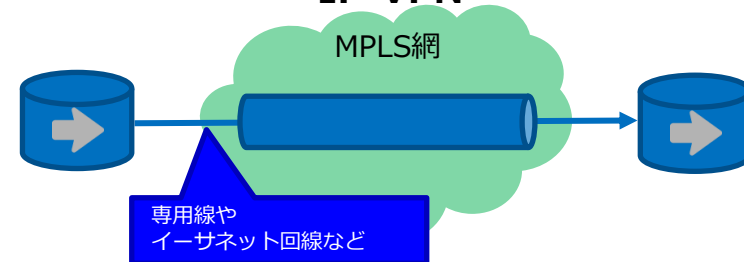
拠点間を結ぶためにネットワーク層・データリンク層にて、通信の機密性を担保する技術を仮想プライベートネットワークと言います。

サービス	内容	回線タイプ
インターネットVPN	公衆インターネット上でVPNを構築し、安全な通信を行うネットワーク	公衆インターネット
エントリーVPN	特に中小企業や個人向けの低コストで簡単に導入できるネットワーク	公衆インターネット
IP-VPN	インターネットを使用せず、キャリア（通信事業者）が提供するMPLS（Multiprotocol Label Switching）で実現するネットワーク	MPLS専用ネットワーク
広域イーサネット	通信事業者のイーサネット（Ethernet）技術を使って、異なる拠点を直接接続するネットワーク	専用イーサネット

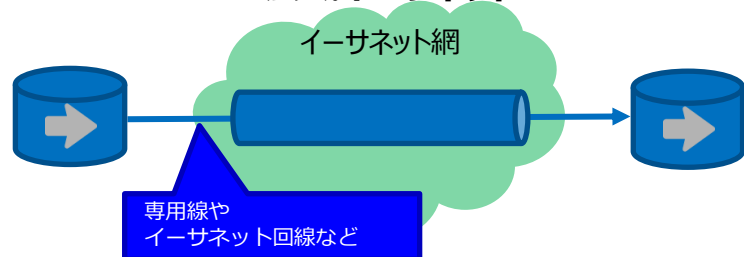
インターネットVPN・エントリーVPN



IP-VPN



広域イーサネット



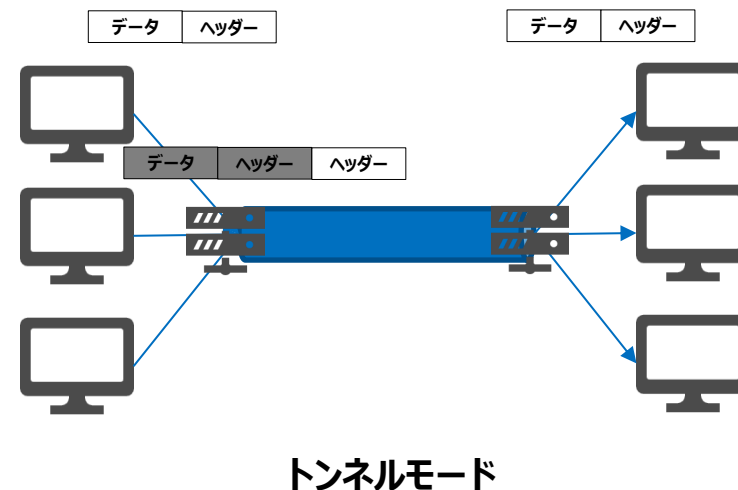
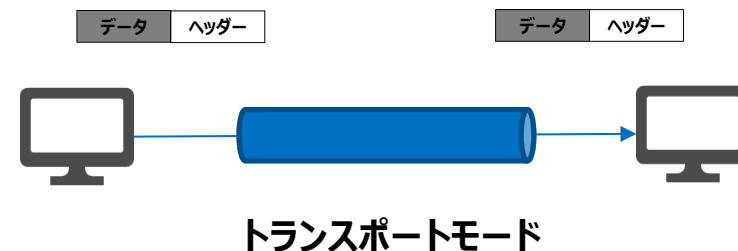
ネットワークプロトコル

セキュアプロトコル

● インターネットVPN

IPsec (Internet Protocol Security)

- ネットワーク層で暗号化通信を実現します。
- IPsecには、認証と改ざん防止のみを行うAH (Authentication Header) と、データの暗号化を行うESP (Encapsulated Security Payload) が提供されています。
- IPsecを使って通信する際に利用する論理的な通信路SA (Security Association) を確立する際、IKE (Internet Key Exchange protocol) により暗号化のための鍵を交換します。
- データ部分のみを暗号化する**トランスポートモード (transport mode)** とヘッダとデータの両方を暗号化する**トンネルモード (tunnel mode)** があり、IPsecを用いたインターネットVPNによって複数コンピュータを管理するような拠点間を接続する場合にはトランスポートモードを採用します。



ネットワークプロトコル

セキュアプロトコル

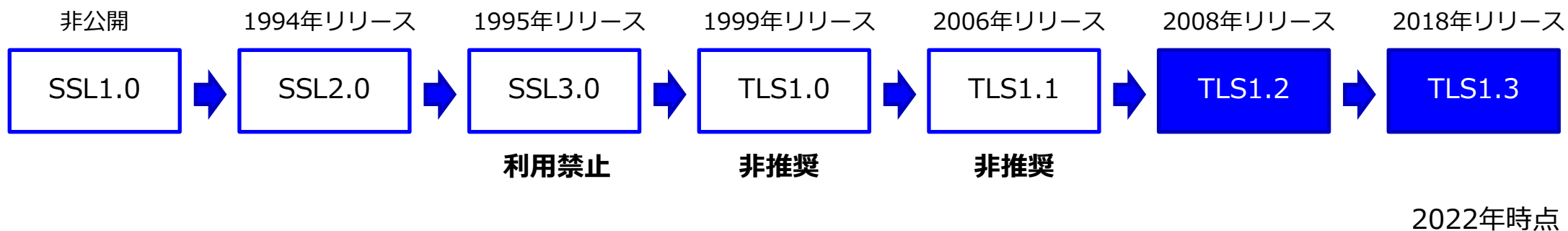
●インターネットVPN

SSL (Secure Sockets Layer)

/TLS (Transport Layer Security)

- ・セッション層で暗号化通信を実現します。
- ・SSL/TLSは、他のアプリケーションと合わせて利用されます。SSL/TLSと他プロトコルの組み合わせにより、そのプロトコルの呼び名、ポート番号が変わります。

通信プロトコル	通信の秘蔵性	ポート番号
HTTP	平文通信	80
HTTPS	暗号通信	443
FTP	平文通信	21
SFTP	暗号通信	22



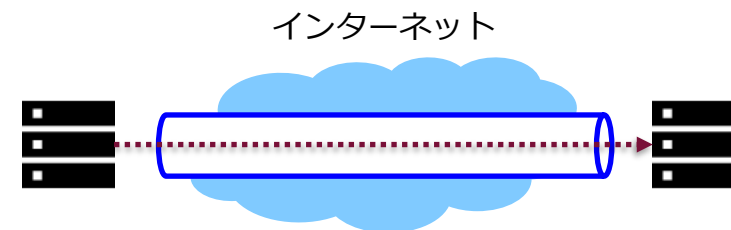
ネットワークプロトコル

セキュアプロトコル

●IP-VPN

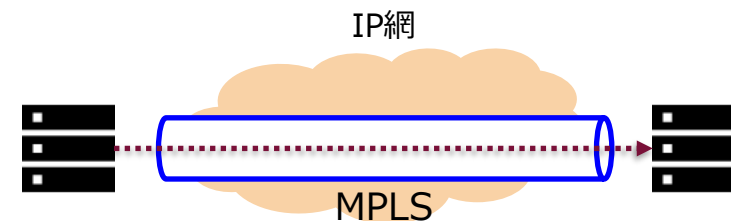
Multi-Protocol Label Switching

- IP-VPNで利用されるのが、マルチプロトコルラベルスイッチングです。マルチプロトコルラベルスイッチング（MPLS、Multi-Protocol Label Switching）は、ラベルを介してWANデータを転送する方法を提供します。
- MPLSネットワークは、ATM、フレームリレー、IPなどのさまざまなタイプのネットワークトラフィックを伝送できます。転送機能は、ルータの経路選択がIPヘッダの情報を使用するのにに対し、MPLSではラベルと呼ばれる識別情報を用いて転送を行います。



IPsec、SSL/TLS、L2TP/IPsec、PPTP

インターネットVPN



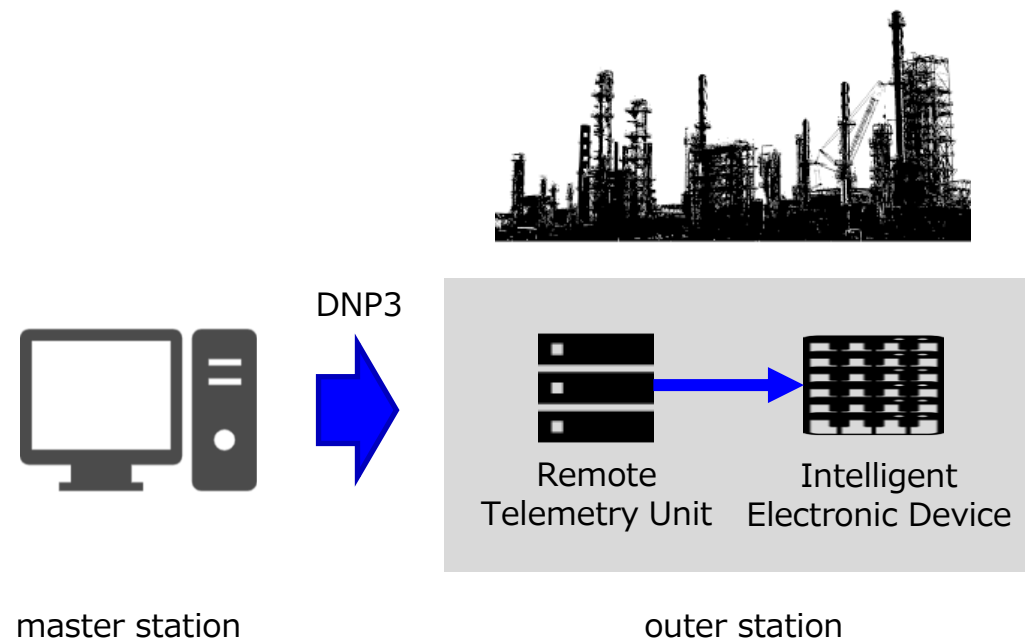
IP-VPN

ネットワークプロトコル

コンバージドプロトコル

●分散ネットワークプロトコル（DNP3、Distributed Network Protocol）

- ・ 電力会社や水道施設などの工業分野でよく利用されるSCADA（Supervisory Control And Data Acquisition）のオープン通信プロトコルセットです。
- ・ マスターステーションと呼ばれる中央制御機構から、各種デバイスとなる高性能電子装置（IED）や統括するリモートターミナルユニット（RTU）などからなるアウトステーションとの通信に利用します。
- ・ 安定度の低い通信回線を利用しても確実にデータの送受信が可能であり、広域分散設備の制御に導入されています。



SCADAシステム

ネットワークプロトコル

コンバージドプロトコル

●ストレージプロトコル

FCoE (Fiber Channel over Ethernet)

- ストレージプロトコルであるFibre Channel (FC)をイーサネット上で動作させる技術です。
- 従来のFibre Channel SAN (Storage Area Network) のインフラを活かしながら、ネットワークインフラを統合するために設計されています。

iSCSI (Internet Small Computer System Interface)

- SCSI (Small Computer System Interface) のコマンドをIPネットワーク上で転送する技術です。
- SCSIのコマンドをTCP/IP経由で伝送するため、一般的なイーサネットインフラを使用して、ストレージへのアクセスを提供します。

項目	FCOE	iSCSI
プロトコル	Fibre Channelをイーサネット上で実装	SCSIコマンドをIP上で実装
動作レイヤー	レイヤー2 (データリンク層)	レイヤー3 (ネットワーク層)
トラフィック形式	Fibre Channelフレームをイーサネットでカプセル化	SCSIコマンドをTCP/IPでカプセル化
速度	高速 (10Gbps以上)	速度はネットワーク帯域に依存 (通常10Gbps以下)
付属	CNA (Converged Network Adapter) と FCoE対応スイッチが必要	一般的なイーサネット機器を利用可能

ネットワークプロトコル

コンバージドプロトコル

● 高速インターコネクトプロトコル

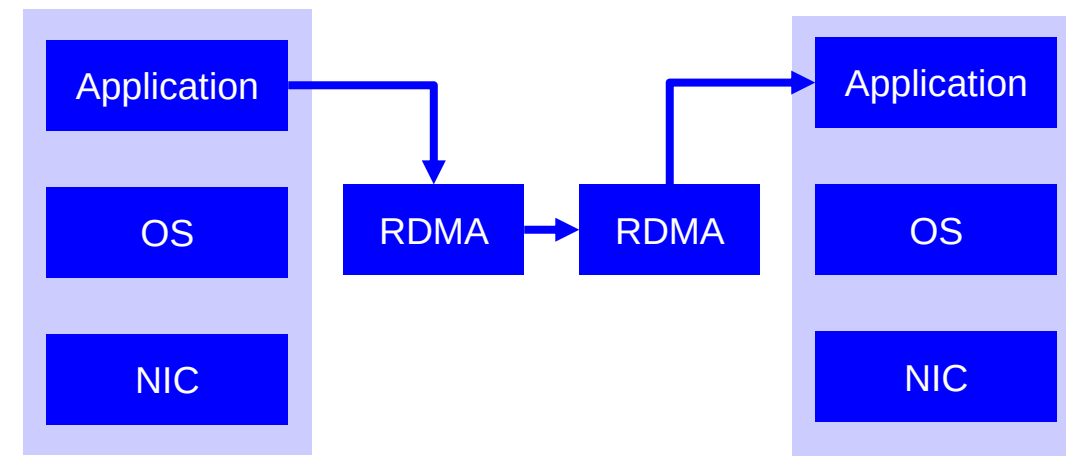
InfiniBand over Ethernet (IBoE)

- InfiniBandプロトコルをイーサネットインフラ上で動作させる技術です。
- InfiniBand (IB)は、高帯域幅と低遅延を提供する高性能ネットワークプロトコルで、主にデータセンターやHPC（High Performance Computing）で使用されます。
- 特に、RDMAによる低遅延が求められる場面に適しています。

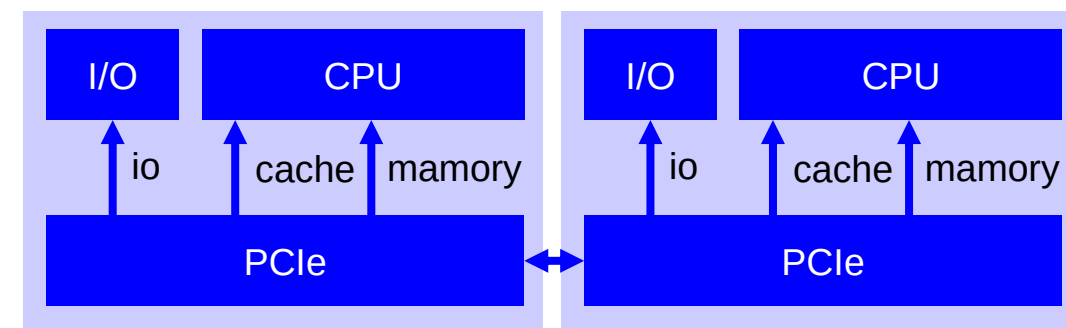
● キャッシュコヒーレントプロトコル

Compute Express Link (CXL)

- PCIeインターフェースをベースにした新しいキャッシュコヒーレントインターフェース規格です。



RDMAはCPUの介入なしに直接メモリからメモリに転送します



CXLはPCIeの物理レイヤーを利用して通信を行います

ネットワークプロトコル

ルーティングプロトコル

●ルーティングプロトコル

静的ルーティング

- ルーティング経路を宛先と次の遷移するルーターを事前に登録（ルーティングテーブルに記録）しておく方法です。
- しかし、一部の機器が故障した場合、その時点でパケットを伝送できなくなり、手動で変更するまで通信障害となります。

Distance-vector routing protocol

- ルーター間で定期的にルーティングテーブルを交換します。
- ディスタンスベクタールーティングプロトコルの中では、RIP（Routing Information Protocol）が有名です。RIPv1はクラスフルルーティング、RIPv2はクラスレスルーティングを行います。
- RIPは、ホップ数（経由するルータの数）で最大ホップ数は15、16ホップの経路は到達不能なルートとして扱う。定期的（30秒）にテーブル全体を隣接ルータに通知し、障害発生時はトリガードアップデート行い、その経路を封鎖します。
- あるルータから来たパケットを送られたルーターに送り返してしまう問題（**ルーティングポイズン**）があるため、他のルーターからもらったルート情報は、その情報をくれたルータが参考しないようにメトリック16を付けて、その情報をくれたルータに通知します（**スプリットホライズン**）。

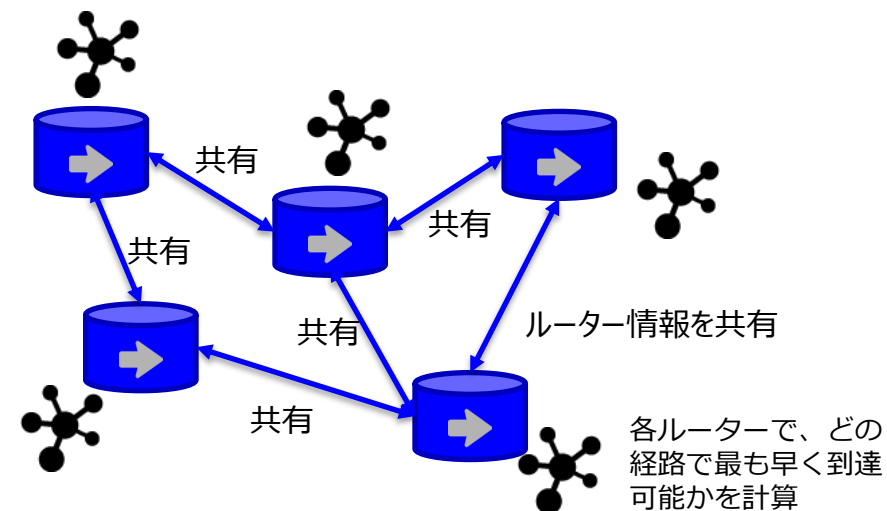
ネットワークプロトコル

ルーティングプロトコル

●ルーティングプロトコル

Link-state routing protocol

- ポップ制限を持たせない大規模ネットワークに対応したルーティングです。
- リンクステートルーティングプロトコルの中では、OSPF (Open Shortest Path First) が有名です。
- 各ルーターがネットワーク全体の情報を共有し、最短経路を計算 (Dijkstraアルゴリズム) します。



- ① Helloパケットを隣接するルーターと交換し、隣接関係を確立します。
- ② 各ルーターはLink State Advertisement (LSA) を送信し、Link State Database (LSDB) を作成します。
- ③ LSDBには、ルーターが受け取ったLSAという情報が格納されます。
- ④ LSDBに基づいて、各ルーターはネットワーク全体のトポロジマップを作成します。
- ⑤ そのトポロジマップから、SPFアルゴリズムによりSPFツリーと呼ばれるネットワーク構成図を作成し、最短経路を計算します。



ネットワークデバイス

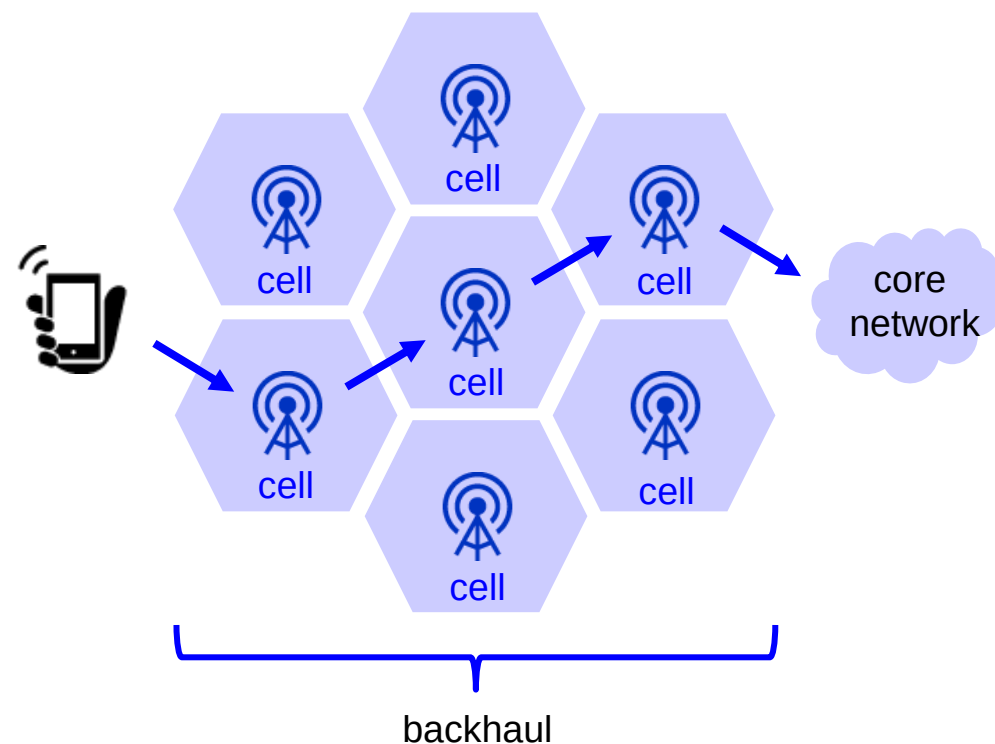
ネットワークデバイス

セルラー／モバイルネットワーク

●セルラーネットワーク（cellular network）

- セルラーネットワークとは、無線通信技術を利用して、広範囲の地域にわたってモバイルデバイス間の通信を提供するネットワークのことです。
- 地理的なエリアを小さなセル（cell）と呼ばれる領域に分割し、各セル内に設置された基地局を通じて通信が行われます。

世代	実現した技術
1G	アナログ音声通信
2G	デジタル音声通信、SMS（テキストメッセージ）
3G	インターネット、ビデオ通話
4G（LTE）	高速ブロードバンド通信、ストリーミングの普及
5G	IoT（モノのインターネット）



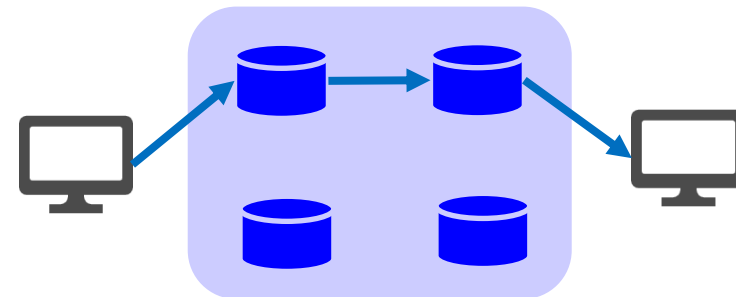
ネットワークデバイス

セルラー／モバイルネットワーク

●データ通信ネットワーク

回線交換ネットワーク (Circuit Switching Network)

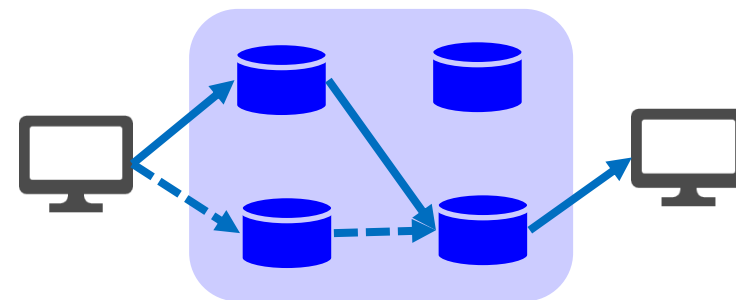
- 通信の前に専用の回線を確保し、通信を行うネットワークです。
- リアルタイムの音声通話やビデオ会議など、遅延が問題になる通信に向いています。



回線交換ネットワーク

パケット交換ネットワーク (Packet Switching Network)

- パケットごとに異なる経路で送信し、データを小さなパケットに分割して送信できるネットワークです。
- データを効率的に転送できるため、インターネットや非同期通信に適しています。
- パケット交換ネットワークに関する最初の研究は、国防高等研究計画局（DARPA、Defense Advanced Research Projects Agency）における1960年代初頭に実施されました。その研究は、インターネットの前身であるARPAnetの作成に繋がっています。



パケット交換ネットワーク

ネットワークデバイス

ベースバンド／ブロードバンド

● 信号伝達

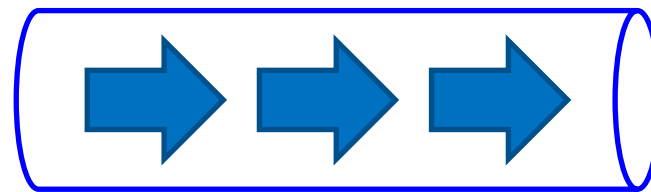
ベースバンド（Baseband）伝送

- 信号を変調せずに、そのまま伝送する方式です。
- 家庭用でよく使われているイーサネットネットワークは、このベースバンド信号伝達になります。

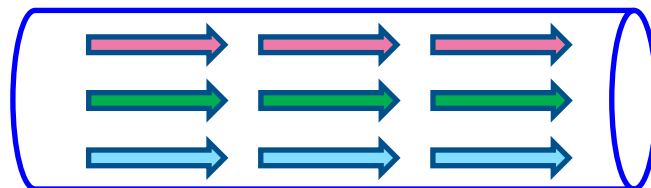
ブロードバンド（Broadband）伝送

- 複数の信号を異なる周波数で変調し、同じ物理的な伝送媒体上で並行して伝送する方式です。
- ケーブルテレビに使われている複数のチャンネルを持つ信号伝達です。

ベースバンド伝送



ブロードバンド伝送



ネットワークデバイス

有線ケーブル

● ツイストペアケーブル（ twisted pair cable ）

- ・ 2本の導線を互いにねじり合わせることで構成されており、外部からの電磁干渉を抑制し、信号を安定して伝送することができます。

● 同軸ネットワークケーブル（ coaxial network cable ）

- ・ 金属製のシールドから絶縁体で分離された内部銅コアがあり、外層はプラスチックである。絶縁体は、コアが金属シールドに接触するのを防ぎます。
- ・ 同軸ネットワークケーブルは、衛星およびケーブルTVサービスによく使用されます。
- ・ 同軸ケーブルの電磁干渉（EMI、Electro-Magnetic Interference）に対する耐性が高まり、ツイストペアケーブルと比較して、より高い帯域幅とより長い接続が可能になります。

ツイストペアケーブル規格

カテゴリー	スピード（Mbps）	利用ケース
Cat 1	<1	アナログ音声
Cat 2	4	ARCNET
Cat 3	10	10baseT ethernet
Cat 4	16	トークンリング
Cat 5	100	100baseT ethernet
Cat 5e	1000	1000baseT ethernet
Cat 6	1000	1000baseT ethernet

ネットワークデバイス

有線ケーブル

● 光ファイバネットワークケーブル (Optical fiber cable network)

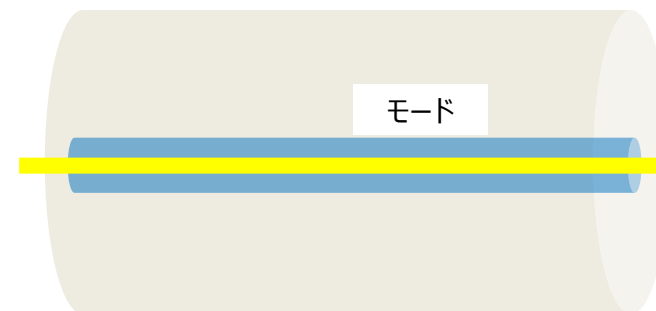
- 光ファイバネットワークケーブルは、膨大な量の情報を伝送でき、ツイストペアや同軸などの銅ケーブルよりもはるかに遠い長距離の伝送に使用できます。

シングルモードファイバ (Single-Mode Fiber)

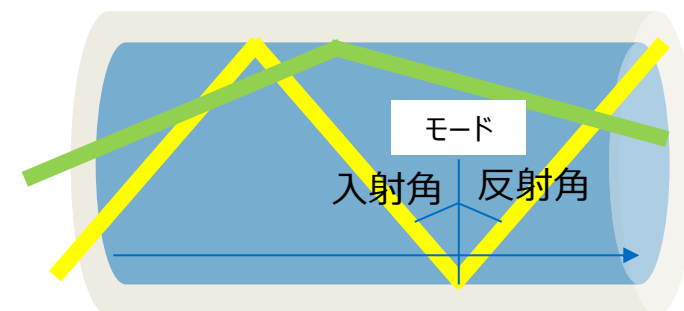
- 一度に1つのタイプの光モードを使用します。
- シングルモードファイバーでは、コアの直径を細くすることで1つのモードだけが通るため、長い距離を伝送しても信号がひずみが生じにくい特徴があります。

マルチモードファイバ (Multi-Mode Fiber)

- 光の複数のモード（パス）を使用します。
- マルチモードファイバはコアの直径が太いため、複数のモード（経路）が生じ、同じ信号でも受信側に届く時間がずれ、信号がひずみが生じやすい特徴があります。光ファイバが長いほど大きくなるため、長距離に向きません。



シングルモードファイバ



マルチモードファイバ

ネットワークデバイス

有線ケーブル

● 光ファイバネットワークケーブル（Optical fiber cable network）

多重シグナル

- 1本のファイバや回線で複数のデータ信号を同時に伝送するための技術です。

多重化技術

- 時分割多重化（TDM: Time Division Multiplexing）とは、時間を細かく分割し、異なる時間スロットにデータを割り当てて伝送する技術です。
- 波長分割多重化（WDM: Wavelength Division Multiplexing）とは、光ファイバで異なる波長（色）の光を同時に伝送する技術です。
- 空間分割多重化（SDM: Space Division Multiplexing）とは、複数の物理的チャネル（ファイバコアや波導）を使ってデータを同時に伝送する技術です。

ネットワークデバイス

有線ケーブル

●イーサネット（Ethernet）

- ・ コンピュータネットワークにおいて広く使われている通信技術であり、主にローカルエリアネットワーク（LAN）でデバイス同士を接続するために使用されます。
- ・ イーサネットは、データを「フレーム」と呼ばれる単位に分割し、ネットワーク内のデバイス間で送受信します。
- ・ **衝突（Collision）** は、ネットワーク通信において、複数のデバイスが同時に同じ通信チャネルにデータを送信しようとしたときに発生する現象です。
- ・ イーサネットの初期の技術である半二重通信や、共有メディアネットワークで起こります。

イーサネット名	タイプ	速度[メガビット]	最大距離[m]
10Base2 'Thinnet'	バス	10	185
10Base5 'Thicknet'	バス	10	500
10BaseT	スター	10	100
100BaseT	スター	100	100
1000BaseT	スター	1000	100

ネットワークデバイス

有線ケーブル

●イーサネット (Ethernet)

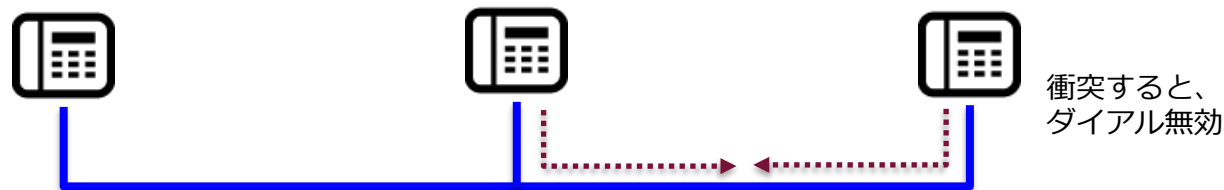
CSMA/CD

- 1本のケーブル上 (1つのネットワークの媒体上) を複数のノードがお互いにアクセス (Multiple Access) できるようになります。

ARCNET/トークンリング

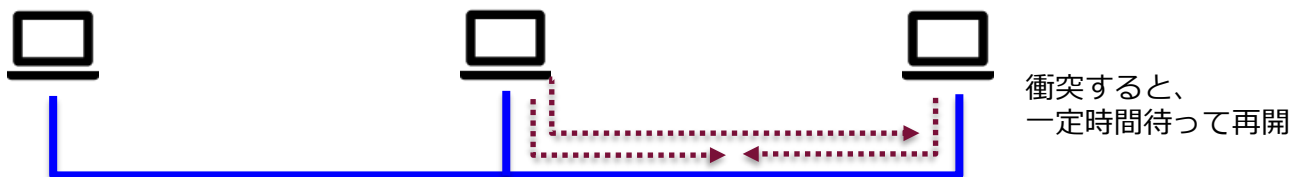
- 端末からネットワークに回線を占有するためのトークンを伝送します。
- トークンをキャッチすると、端末はネットワーク上のトラフィックを読み書きできます。

従来の電話回線通信プロセス



- ① 受話器を持ち上げると、回線がアイドル状態かどうかを確認
- ② 回線がアイドル状態でない場合は、電話を切り、再試行するまで待機
- ③ 回線がアイドル状態の場合は、ダイヤル実行
- ④ 同時に受話器を持ち上げると両方でアイドル状態と判定され、衝突が起これば、ダイヤルは無意味となる。

CSMA/CDの衝突回避プロセス



- ① イーサネットフレームを送りたいPC端末はケーブルの通信状況（電気信号の状況）を確認します。
- ② フレームが伝送されていなければ自身のフレームを送信します。
- ③ 複数の機器が同時に送信してデータが衝突する場合、ある時間を待って送信をやり直します。
- ④ 信号を感知 (Carrier Sense) しフレーム伝送を行い、フレームが衝突を検出 (Collision Detection) するとランダムな時間を待ち送信を開始します。

ネットワークデバイス

無線通信

●ワイヤスローカルエリアネットワーク（WLAN、Wireless LAN）

ISMバンド

- 産業、科学、および医療（ISM）バンドは、ライセンスなしで使用するために確保されており、連邦通信委員会（FCC）などの組織からライセンスを取得する必要はありません。
- 国際的に使用されている一般的なISM帯域は、2.4GHzと5GHzです。
- 5GHzの方が通常混雑が少ないですが2.4GHzの方が波ほど壁やその他の障害物を透過します。

種類	最大速度	周波数
802.11	2Mbps	2.4GHz
802.11a	54Mbps	5GHz
802.11b	11Mbps	2.4GHz
802.11g	54Mbps	2.4GHz
802.11n	600Mbps	2.4GHz or 5GHz
802.11ac	1.3Gbps	5GHz

IEEE 802.11ワイヤレスには、さまざまな周波数と速度を使用する標準があります。

ネットワークデバイス

無線通信

●SSID (Service Set Identifier)

- ・ 802.11 WLANSは、ネットワーク名としてサービスセット識別子（SSID、Service Set Identifier）を使用します。
- ・ SSIDブロードキャストが無効になっている場合でも、モニターモードのワイヤレススニファーは、クライアントがWLANに参加するときに使用するSSIDを検出します。

●IEEE 802.11i

- ・ IEEE 802.11iは、Wi-Fiネットワークにおけるセキュリティの強化を目的とした規格です。
- ・ AESとCCMPを使用して、強力なデータ暗号化を実現し、データの盗聴や改ざんを防ぎます。
- ・ 802.1XとEAPを通じて、正当なユーザーやデバイスのみがネットワークにアクセスできるようにします。
- ・ CCMPはメッセージ認証コード（MAC）を提供し、データが途中で改ざんされていないかを検証します。

ネットワークデバイス

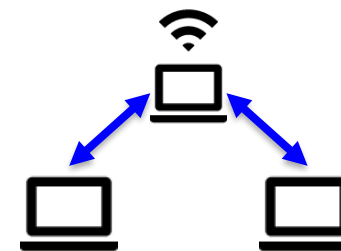
無線通信

● 無線のモード

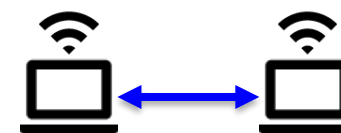
- それぞれ無線デバイスがどのように通信を行うか、またどのようにネットワークに接続するかを定義するモードがあります。

モード名	説明	用途
マネージドモード (Managed Mode)	クライアントがアクセスポイントに接続するモード	PC、スマホ
マスターモード (Master Mode)	無線デバイスがアクセスポイントとして動作するモード	ルーター、Wi-Fiアクセスポイント
アドホックモード (Ad-hoc Mode)	アクセスポイントを使わず、デバイス同士が直接通信するモード	一時的なP2P接続、ローカルネットワーク
モニターモード (Monitor Mode)	無線通信を傍受し、通信の内容をキャプチャするモード	ネットワーク解析、セキュリティ監視

マネージドモード／マスターモード



アドホックモード



モニターモード



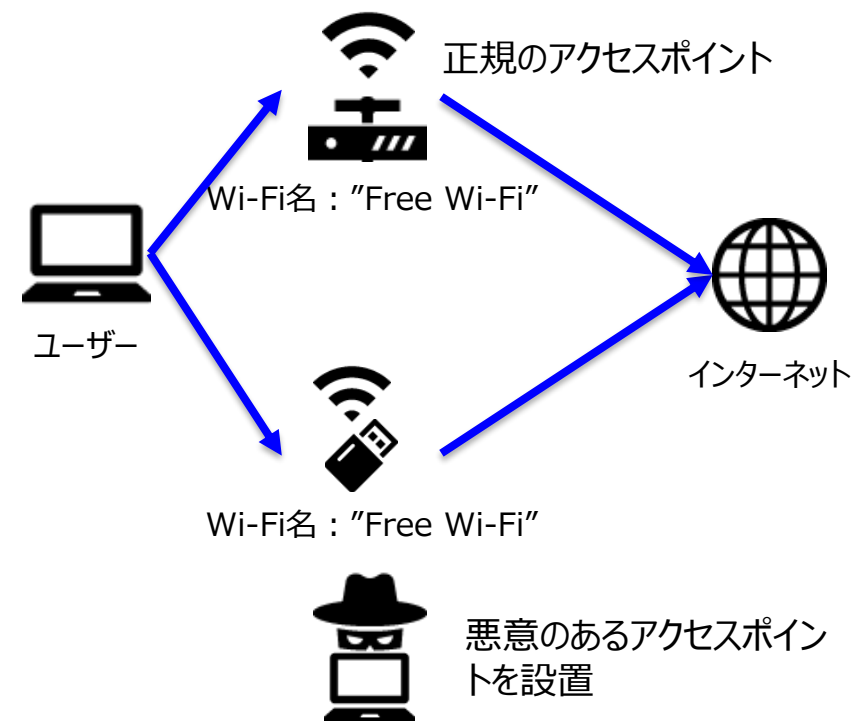
ネットワークデバイス

無線通信

● ユーザーに対するネットワーク攻撃

悪魔の双子攻撃 (Evil Twin Attack)

- ホテルやカフェなどの無料Wi-Fiの偽物を設置し、ユーザー情報を盗みだす攻撃です。
- 無料のWi-Fiが危険といわれる原因であり、インターネットに接続する際の同意画面も偽装である場合もあるため、見慣れている画面だからと安心するのは非常に危険です。



ネットワークデバイス

無線通信

● Bluetooth／Zigbee

項目	Bluetooth	Zigbee
通信範囲	約10～100m	約100m
転送速度	最大3Mbps	最大250kbps
消費電力	中程度 (Bluetooth Low Energy は低電力)	非常に低電力
ネットワークトポロジー	スター型	メッシュ型
用途	イヤホン、スマホ	スマートホーム

Bluetoothの脆弱性

Bluetoothは128ビットE0対称ストリーム暗号を使用しますが、機密性があるわけではありません。機密性の高いデバイスは、他のBluetoothデバイスによる自動検出を無効にする必要があります。

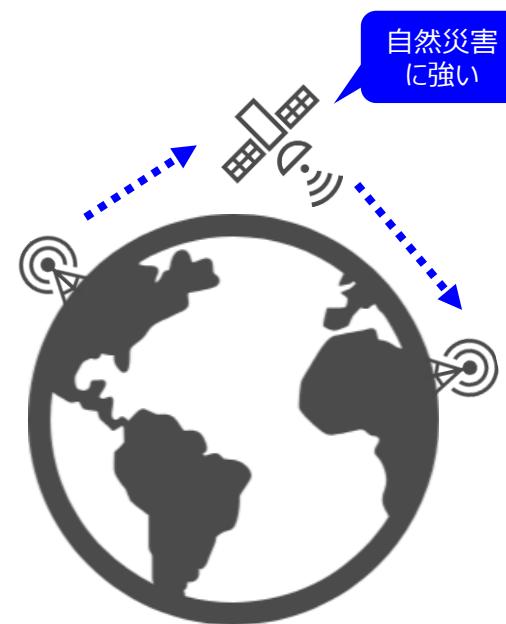
検出の「セキュリティ」は、Bluetoothアダプタの48ビットMACアドレスの機密性に依存しており、MACアドレスは2つの番号に構成されており、前半部分が組織、後半部分が端末を示し組織番号は公開されているため、後半部分の端末を示す24ビットを推測することがBluetoothへの攻撃となります。

ネットワークデバイス

無線通信

● 衛星通信

- ・ 地球の上空にある人工衛星を利用して、地上の離れた場所同士で通信を行う技術です。
- ・ 地球の広い範囲をカバーすることができるため、遠隔地や海洋、航空機などのインフラが整備されていない場所でも通信が可能になります。
- ・ 自然災害時など地上の通信インフラが損傷しても機能し続けることが多く、緊急時の通信手段として利用されます。



ネットワークデバイス

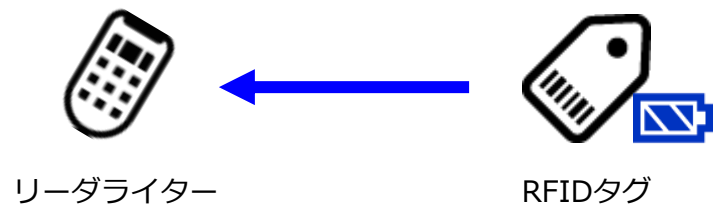
無線通信

● RFID (Radio Frequency Identification)

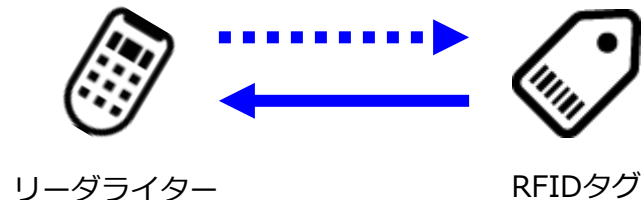
- 無線通信を使って物体や人に取り付けられたタグ（RFIDタグ）から情報を読み取る技術のことです。

項目	アクティブ型	パッシブ型
信号送信	能動的にリーダーに対して信号を送信	受動的にリーダーに対して信号を送信
電源	内臓バッテリーを搭載	リーダーからの電波で動作
通信速度	高い	低い
用途	高速道路のETC	商品管理

アクティブ型



パッシブ型



ネットワークデバイス

無線通信

● Near Field Communication (NFC)

- ・ 近距離無線通信技術の一種で、約10cm以内の短い距離でデータのやり取りを可能にする技術です。

項目	RFID	NFC
通信方式	一方向通信 (タグ→リーダー)	双方向通信が可能
関連の標準	ISO/IEC TR 18047、 ISO/IEC 18000、 EPCglobal	ISO/IEC 18092、 ISO/IEC 21481 (NFCIP-2)、ECMA- 340
用途	在庫管理、交通機関	モバイル決済、データ交換



ネットワークデバイス

伝送媒体

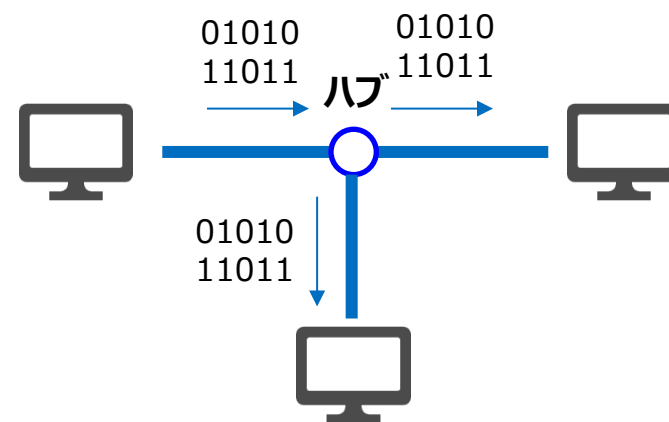
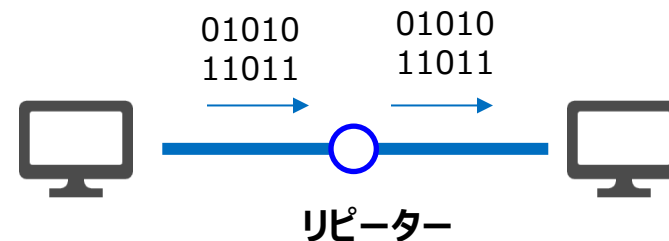
●レイヤー1（物理層）のデバイス

リピーター（repeater）

- ある一方のポートでビットを受信し、もう一方のポートでビットを繰り返します。
- ネットワークケーブルの長さが足りない場合に利用されます。

ハブ（hub）

- 1つのポートでビットを受信し、他のすべてのポートでビットを繰り返します。
- ハブはネットワークトラフィックの機密性がないため、実運用で利用されることはありません。フォレンジックを調査といったトラフィックを調査する目的で利用されます。



ネットワークデバイス

伝送媒体

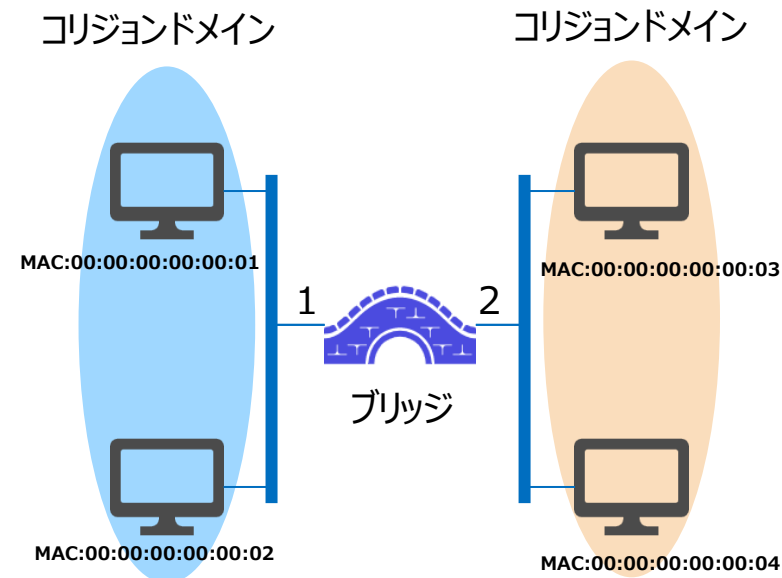
●レイヤー2（データリンク層）のデバイス

ブリッジ（bridge）

- 複数のネットワークセグメントを結び、受信したデータのMACアドレスを参照して中継のするかを判断します。
- 接続されたセグメントから流れてきたデータの宛先情報が、もう一方のセグメントに向けのものであれば中継し、それ以外は破棄します。
- ネットワークセグメントのことを**コリジョンドメイン（collision domain）**と呼びます。

スイッチ（switch）

- 3つ以上のポートを持つブリッジです。
- ポートを複数持つため、スイッチポートごとに1つのデバイスのみを接続することが推奨されています。



1 MAC:00:00:00:00:00:01
1 MAC:00:00:00:00:00:02
2 MAC:00:00:00:00:00:03
2 MAC:00:00:00:00:00:04

ネットワークデバイス

伝送媒体

●レイヤー2（データリンク層）のデバイス

仮想LAN（VLAN、Virtual LAN）

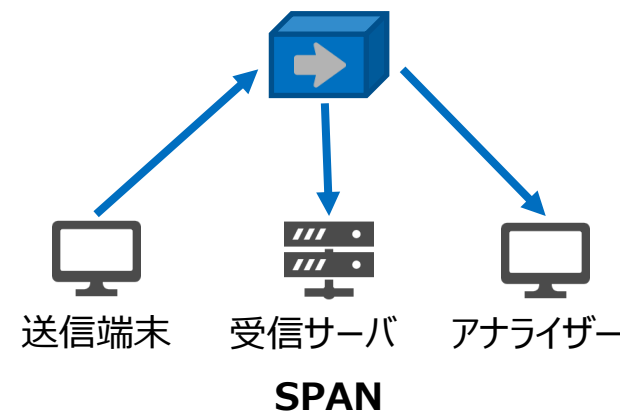
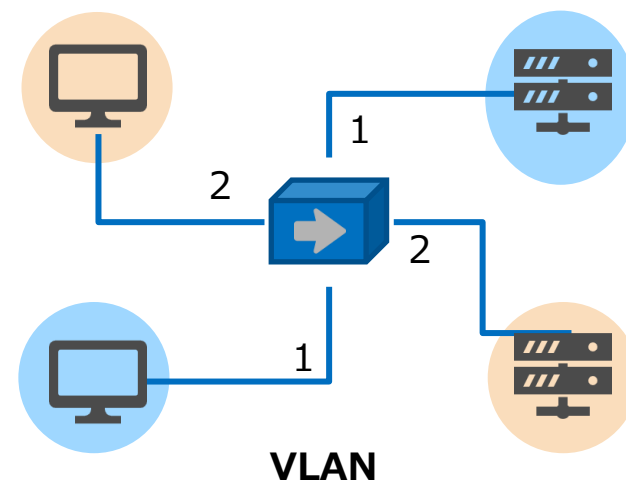
- スイッチのポートを仮想的（ソフトウェアによって）に区分し、コリジョンドメインを分ける技術です。ポートの物理的位置は隣接している必要がありません。

プライベートVLAN（PVLAN、Private LAN）

- それぞれのポートをプライベートVLAN、セカンダリVLAN（隔離VLAN、コミュニティVLAN）いずれかに指定します。プライベートVLANはすべてのポートに通信可能、隔離VLANはプライベートVLANとのみ通信可能、コミュニティVLANは同じコミュニティポート番号を振られた端末と通信可能になります。

SPAN（Switched Port ANalyzer）

- スイッチの特定のポートで送受信したフレームを他のポートへ転送（コピー）を行う技術です。



ネットワークデバイス

伝送媒体

●レイヤー3（ネットワーク層）のデバイス

ルーター（router）

- 異なるネットワーク間でデータを中継し、最適な経路を選んでデータを送信するネットワーク機器です。
- ルーターはネットワークのルーティング（地図）を持ち、データパケットが最も効率的な経路を通過して目的地に到達できるようにします。





ネットワーク制御

ネットワーク制御

ネットワークプレーン

● ネットワークプレーン

Data plane



- 実際のデータ転送と処理
- パケットの転送、フィルタリング、NAT、QoSの適用
- MPLS、IPv4/IPv6、Ethernet、VLAN

Control plane



- ルーティングやスイッチングの決定、制御
- 経路の計算、ネットワークトポロジの維持
- VLAN、OSPF、BGP、IGP

Management plane



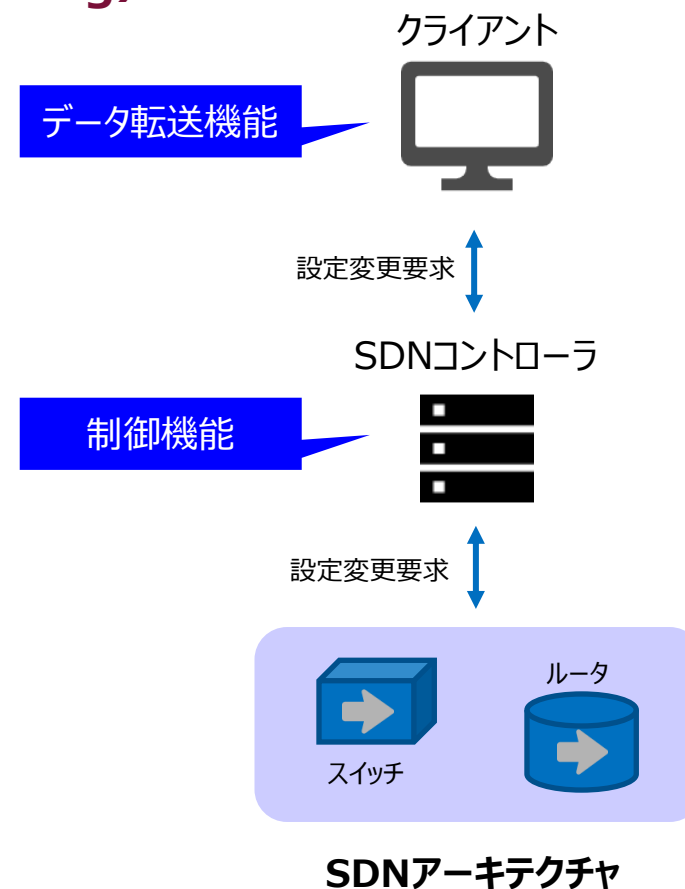
- ネットワーク全体の設定、監視、運用管理
- デバイス設定、障害検出、ネットワーク監視
- SNMP、REST API、SSH

ネットワーク制御

ソフトウェア定義ネットワーク (SDN)

● ソフトウェア定義ネットワーク (SDN、Software Defined Networking)

- ・ ネットワーク機器に対する設定をソフトウェアで制御するものを指します。
- ・ SDNを使用すると、ルーティングなどの設定は、個々のネットワーク機器ではなく、SDNコントローラを介して、遠隔で行うことができます。



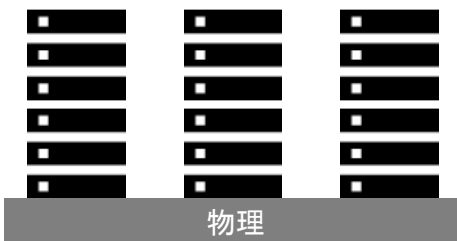
ネットワーク制御

仮想プライベートクラウド（VPC）

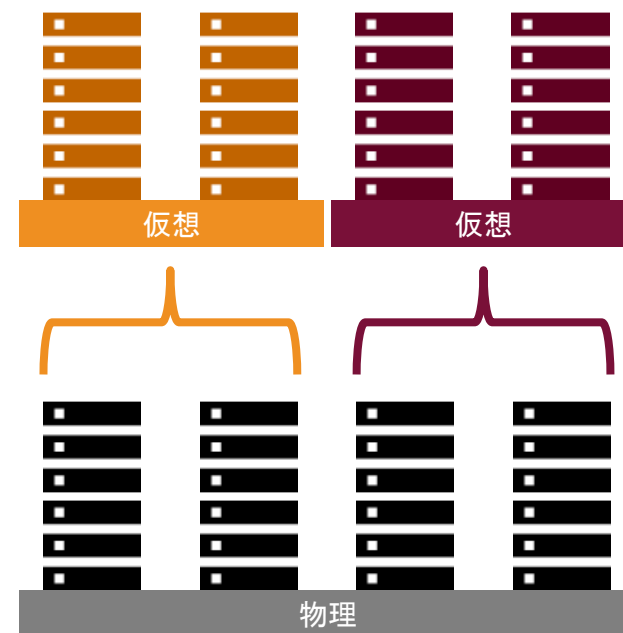
●仮想プライベートクラウド（VPC、Virtual Private Cloud）

- ・パブリッククラウド環境内に構築される仮想的なプライベートネットワークのことを指します。
- ・VPCを利用すると、クラウドプロバイダーが提供する共有のインフラストラクチャ上にありながら、まるで自社専用のネットワークを持っているかのようにクラウドリソースを運用できます。

（純粹な）プライベートクラウド



仮想プライベートクラウド



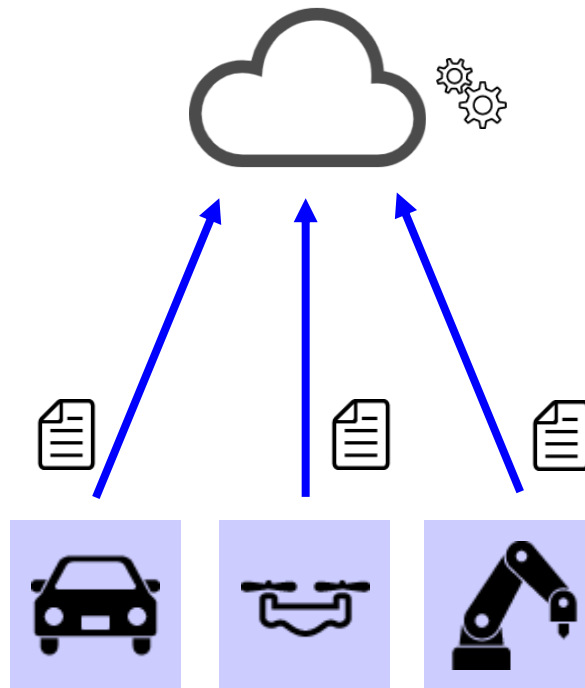
ネットワーク制御

エッジネットワーク

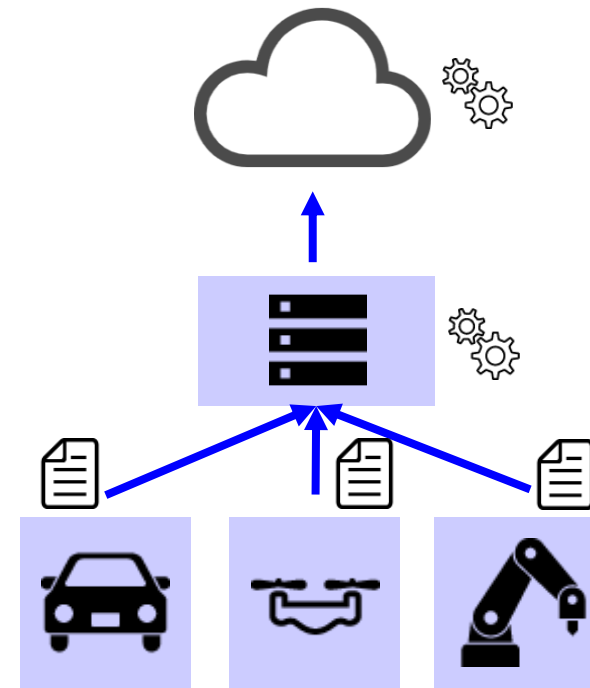
●エッジネットワーク（Edge Network）

- データ処理やストレージ、サービスの提供を、データが生成される「エッジ」（端末やデバイスの近く）で行うネットワークアーキテクチャを指します。
- 従来のクラウドコンピューティングではデータが中央のデータセンターに送られ、そこで処理が行われますが、エッジネットワークではデータが発生する場所に近い地点で処理されるため、遅延を減らし、ネットワークの負荷を軽減します。エッジコンピューティング分、セキュリティ保護する環境が増えます。

クラウドコンピューティング



エッジコンピューティング

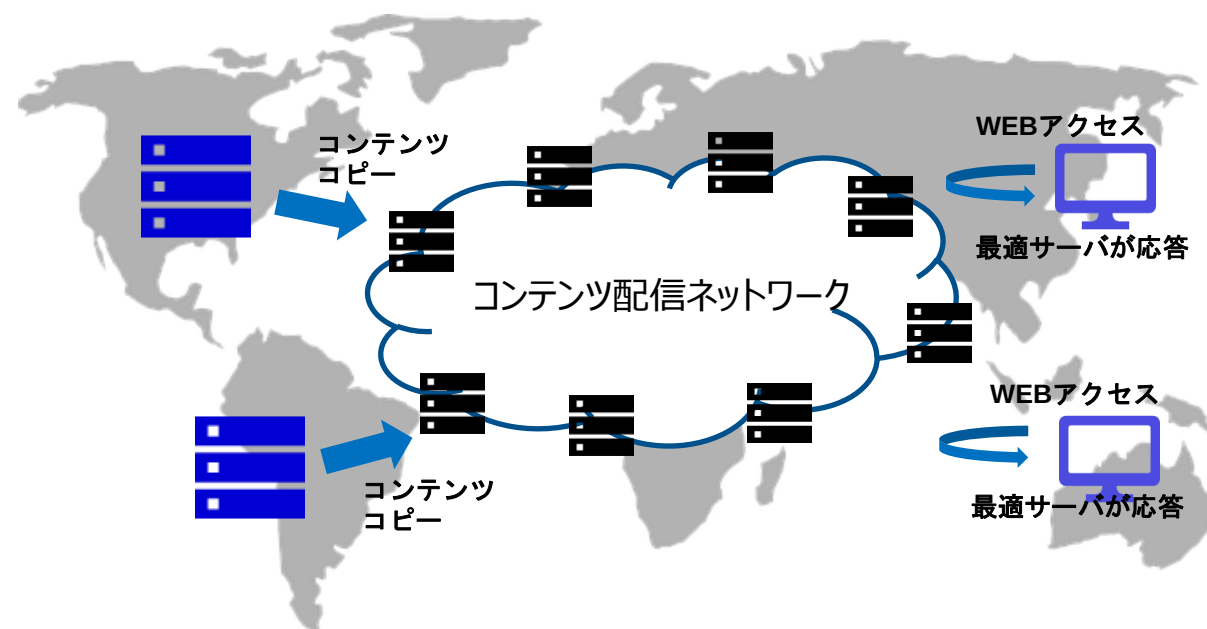


ネットワーク制御

コンテンツ配信ネットワーク

●コンテンツ配信ネットワーク（CDN、Content Delivery Network）

- ・コンテンツ配信キャッシュサーバーを使用して、パフォーマンスを向上させ、ダウンロードされたオンラインコンテンツの待ち時間を短縮します。
- ・エンドユーザーに最も近いサーバーを自動的に決定するため、ユーザーはインターネット上で最も高速で最も近いサーバーからコンテンツをダウンロードします。
- ・例としては、Akamai、Amazon CloudFront、CloudFlare、Microsoft Azureなどがあります。



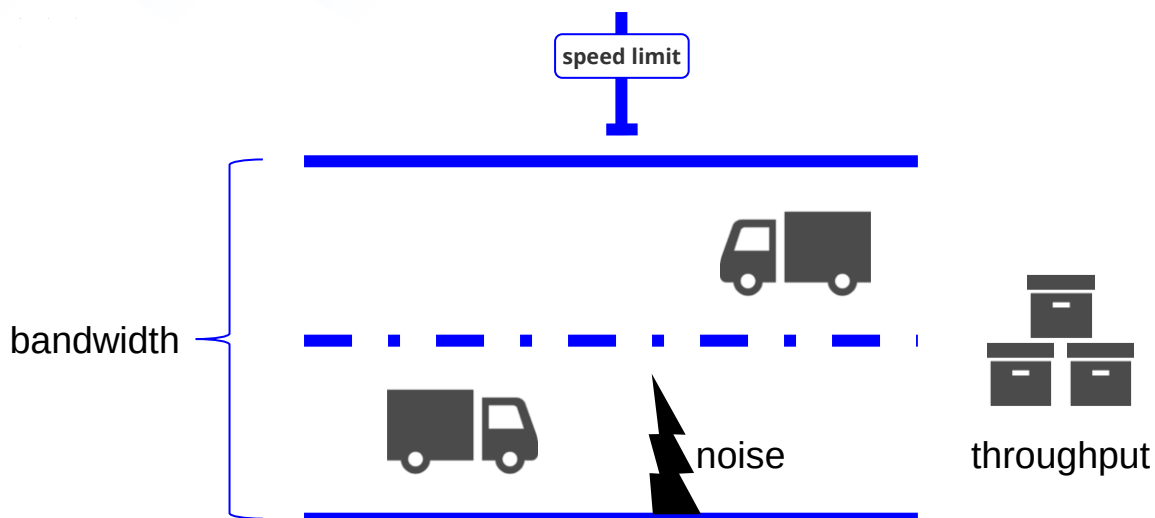
コンテンツ配信ネットワークによるコンテンツ配信の最適化

ネットワーク制御

パフォーマンスメトリクス

●パフォーマンスメトリクス

- ノイズ等により全てのデータが問題なく伝達できるわけではないため、レイテンシーやジッタが上がり、帯域幅が高くても、スループットが出せなくなることがあります。



用語	定義	単位	一言で
帯域幅 (Bandwidth)	通信路が同時に転送できるデータの最大量	Hz (周波数帯域) / bps (ビット毎秒)	理論上の最大値
スループット (Throughput)	実際に送信され、成功したデータ量	bps (ビット毎秒)	実際のデータ量
S/N比 (Signal-to-Noise Ratio)	信号とノイズの比率	dB (デシベル)	通信品質
レイテンシー (Latency)	データが送信されてから受信されるまでにかかる遅延時間	ミリ秒 (ms)	遅延
ジッタ (Jitter)	パケット間のレイテンシーのばらつき。	ミリ秒 (ms)	ばらつき

ネットワーク制御

観測と監視

●可観測性 (Observability)

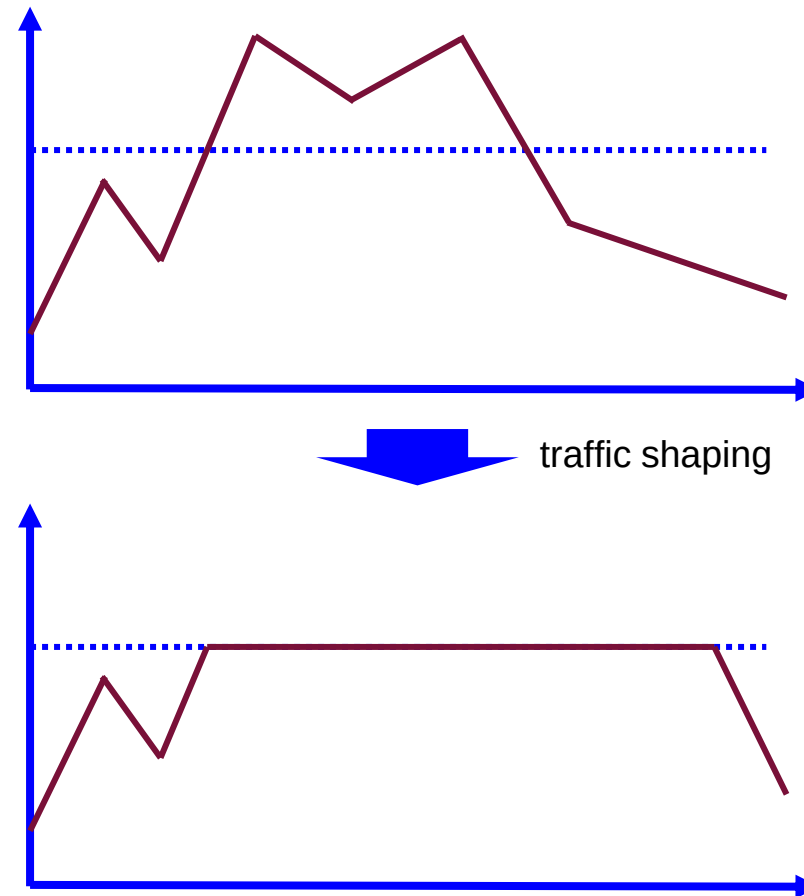
- システムの内部状態を外部から観測可能にするための能力です。
- 現代の分散システムやクラウドベースのアーキテクチャでは、システムが正常に動作しているか、または問題が発生しているかを判断するために重要な概念です。

トラフィックシェーピング (traffic shaping)

- ネットワークトラフィックを制御して、特定の帯域幅を超えないようにする技術です。

サービス品質 (QoS、Quality of Service)

- 他のトラフィックよりも特定のトラフィックを優先する仕組みです。



ネットワーク制御

通信認証

●インターネット接続

Point to Point Protocol (PPP)

- ・プロバイダーとのアクセスのために、サーバーとパソコン／モデム間を結ぶために利用するプロトコルです。
- ・PAP (Password Authentication Protocol) と、CHAP (Challenge Handshake Authentication Protocol) の認証プロトコルが採用されています。
- ・PAPはパスワードが平文で流れますが、CHAPはチャレンジ・レスポンス方式を採用して、パスワードそのものを経路上に流しません。

Extensible Authentication Protocol (EAP)

- ・リンクの確立段階では認証方式を特定せず、接続の検証段階でEAPタイプと呼ばれる特定のEAP認証方式を使う認証フレームワークです。



プロバイダーとの接続

拡張認証プロトコル

認証方式	内容
EAP-MD5	EAPフレームワークにおけるCHAP認証
EAP-TLS	電子証明書を利用したPKI認証を採用
EAP-TTLS	サーバー側は電子証明書、クライアント側ではユーザー名とパスワードを利用
LEAP	シスコシステムズ独自の認証方式

ネットワーク制御

ファイアーウォール

●ファイアーウォール (Firewall)

パケットフィルターファイアーウォール (packet filter firewall)

- パケットフィルターファイアーウォールは、送信元や宛先のIPアドレス、ポート番号に基づいてパケットをフィルタリングします。
- OSI参照モデルの第3層（ネットワーク層）で機能します。

ステートフルファイアーウォール (stateful firewall)

- 通信の接続状態（例えば、TCPの「接続確立」や「終了」など）を追跡し、既存の接続に関連するパケットかどうかを判断します。
- OSI参照モデルの第4層（トランスポート層）で機能します。

プロキシファイアーウォール (proxy firewall)

- クライアント（内部ネットワークのユーザー）と外部のサーバーとの直接通信を行わず、クライアントのリクエストを一度プロキシが受け取り、その後外部のサーバーに対してリクエストを代理で送信します。
- OSI参照モデルの第7層（アプリケーション層）で機能します。

packet filter firewall



ステートフルFW



プロキシFW



ネットワーク制御

ファイアーウォール

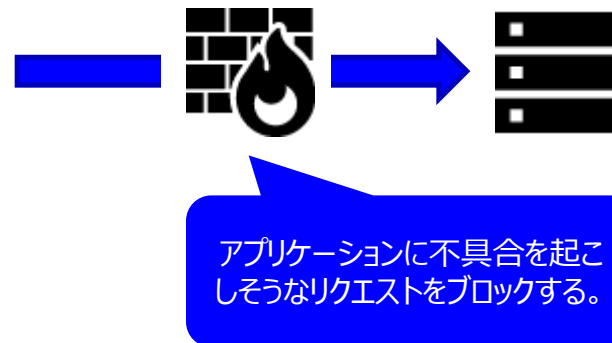
●ファイアーウォール（Firewall）

アプリケーションファイアーウォール（application firewall）

- OSI参照モデルの第7層（アプリケーション層）で機能します。
- アプリケーションには、バッファオーバーフローやSQLインジェクションなど共通する脆弱性があります。アプリケーション自体の通信を制御することで、共通する脆弱性をアプリケーションレベルで解決できます。
- とりわけ、Web通信に対するアプリケーションレベルゲートウェイのことを**WAF（Web Application Firewall）**といいます。

次世代ファイアウォール（Next-generation firewall）

- OSI参照モデルの第2層から第7層で機能します。
- パケットフィルタリングやステートフルに加えて、アプリケーションやユーザーを識別する認可を提供します。



ネットワーク制御

ファイアーウォール

●ファイアーウォールの構成

非武装地域（DMZ、DeMilitarized Zone）

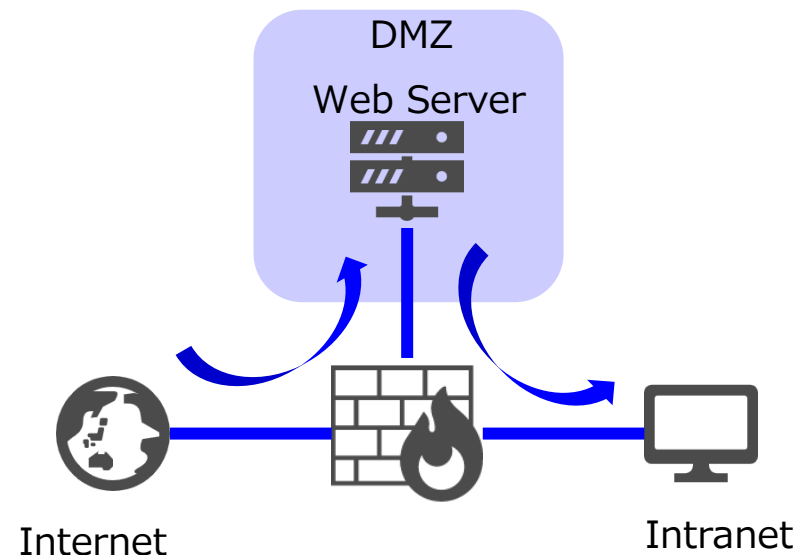
- アクセス制限はしているものの外部と接触するネットワークを非武装地域DMZと呼びます。

シングルファイアウォールDMZ構成

- インターネット、DMZ、イントラネットワークをファイアーウォール一つを使って区分する方法です。

Internal Segmentation Firewall

- 企業や組織の内部ネットワーク内でセグメント間のトラフィックを制御し、セキュリティを強化するためのファイアウォールです。
- ゼロトラストネットワークの実現する一つの技術です。



インターネットからイントラネットワークにアクセスは拒否し、必ずインターネットとDMZ、DMZとイントラネットワークを経由するように設定します。

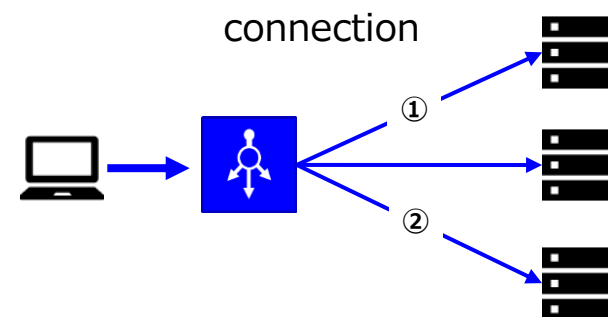
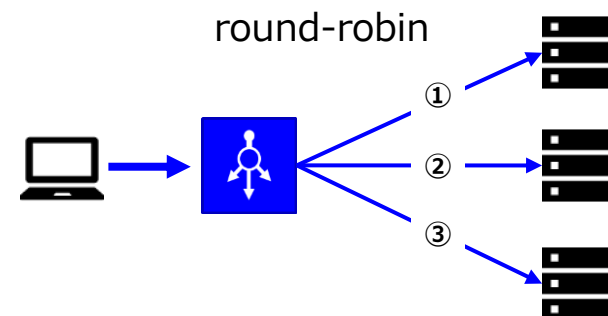
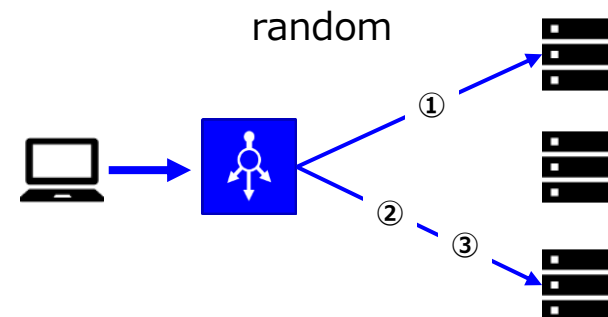
ネットワーク制御

ロードバランサー

●ロードバランサー

- ロードバランシングの目的は、レスポンスタイムを最小化しつつ、システム全体への過負荷を軽減させる事です。
- パーシスタンスとは、セッションが続く限りは同じサーバーを利用させるかどうかを決定するものです。

種類	内容
ランダム	各パケットまたは接続は、ランダムに宛先となる処理サーバーを割り当てられます。
ラウンドロビン	リクエストを送るサーバーを順番にすることで、負荷が均一になるようにします。
重みづけ	送られるリクエスト数は重みによって比率を分け、サーバーの負担が均一になるように調整します。
コネクション数	サーバー側と張っているコネクションの数に合わせて、次にリクエストを送るかを決めます。
地理的な距離	ロードバランサーからの相対的な距離に基づいて宛先を割り当てます。

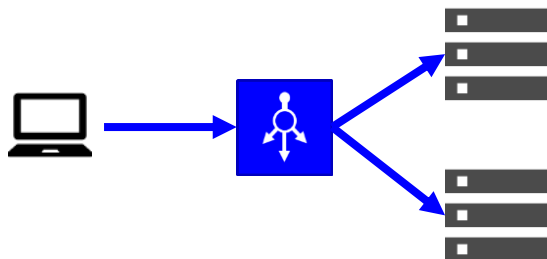


ネットワーク制御

ロードバランサー

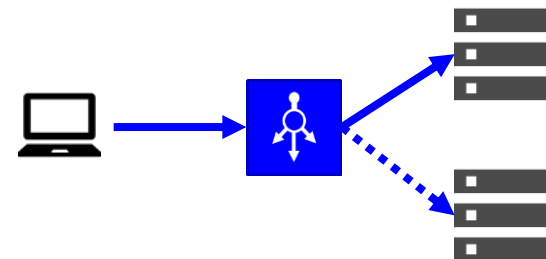
●システムの冗長化

Active-Active



- 全システムが同時に稼働し、負荷を分担する
- 全システムが稼働しているため、性能が向上
- 1台が故障しても他の稼働システムが負荷を引き継ぐ

Active-Passive



- アクティブシステムが通常稼働し、パッシブシステムは待機状態
- パッシブシステムは通常時稼働しないため、資源効率が低い
- アクティブシステムが故障した場合、パッシブが代替



アプリケーション通信

アプリケーション通信

音声／ビデオ／コラボレーション

● リモートミーティングテクノロジー

- デスクトップ共有機能など、ユーザーがインターネット経由でオンライン会議を実行できるようにするテクノロジーです。
- 通常、会議に接続されているすべてのPCでのPowerPointスライドの表示、スプレッドシートなどのドキュメントの共有、場合によってはオーディオやビデオの共有が含まれます。
- 一部のソリューションでは、ユーザーがリモートミーティングテクノロジーで接続されている別のPCが操作できます。



リモート会議テクノロジーアプリの主な確認観点

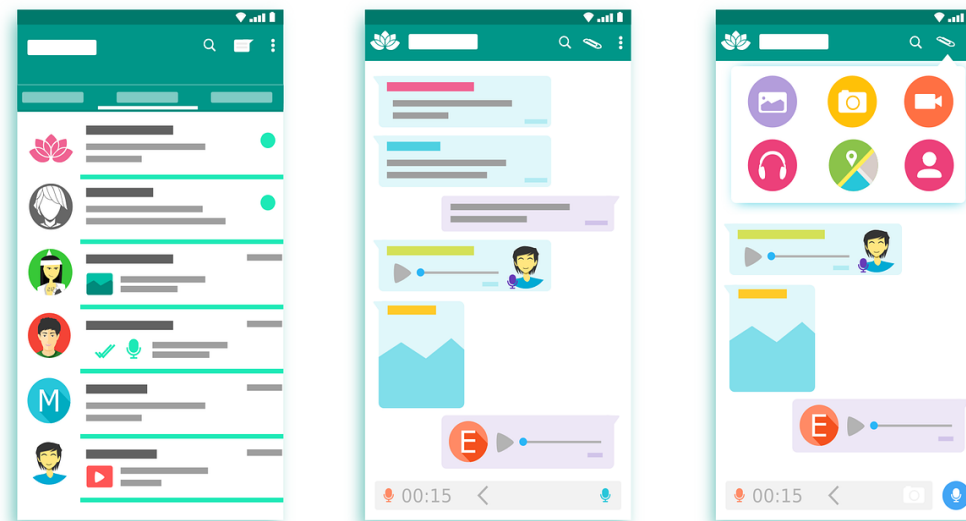
- ✓ 多要素認証などの強力な認証技術を使用しているか。
- ✓ 通信が暗号化されているかどうか。その暗号化は、エンド・ツー・エンドで実施されるのか、中継サーバまでなのか。
- ✓ チャット等でやり取りしているドキュメントなどのコンテンツに対して削除が可能か、どこに保管されるのか。
- ✓ 未承認者に対してプライベートな会議に参加することを拒否できる機能が備わっているか。
- ✓ ユーザーの活動は監査され、ログに記録されるか。
- ✓ リモートミーティングのプラットフォーム自体が、どのようなトラッキングメカニズムを使用しているか。
- ✓ トラッキングを無効にすることができるか、データは何のために収集されるか。
- ✓ 参加者は会議の中で画像、ビデオ、ファイル共有ができるか。

アプリケーション通信

音声／ビデオ／コラボレーション

● インスタントメッセージング

- ・ 2人以上のユーザーがリアルタイムの「チャット」を介して相互に通信が可能となります。チャットは、グループを介して1対1または多対多の場合があります。
- ・ チャットに加えて、最新のインスタントメッセージングソフトウェアのほとんどは、ファイル共有、場合によっては音声およびビデオ会議を可能にしている。
- ・ インスタントメッセージングプロトコルにはIRC (Internet Relay Chat) があります。
- ・ チャットソフトウェアの使用を制御するポリシーと、利用範囲を監視し、必要に応じてブロックするための技術的制御を実施する必要があります。

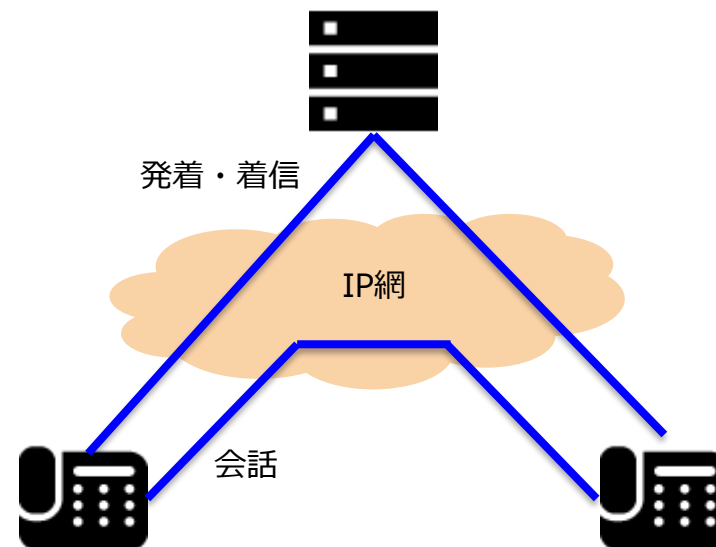


アプリケーション通信

音声／ビデオ／コラボレーション

● VoIP (Voice over Internet Protocol)

- IPネットワークを介して音声を伝送するプロトコルです。
- アナログPOTS (Plain Old Telephone Service) の基本的な機能です。
- 一般的なVoIPプロトコルには、ストリーミングオーディオとビデオを伝送するように設計されたReal-time Transport Protocol (RTP) で提供されています。
- VoIP通話の盗聴は秘密性がないため容易であり、ネットワークが危険にさらされた場合は、携帯電話などの他の方法を使用して帯域外通信を行うか、SRTP (Secure Real-time Transport Protocol) を使用して、機密性、整合性、安全な認証などの安全なVoIPを行うようにしてください。



アプリケーション通信

音声／ビデオ／コラボレーション

● Vishing／Phreaking

- Vishingとは、電話を使った詐欺の一種で、詐欺師が電話で個人情報を引き出そうとする手口です。
- Phreakingとは、電話ネットワークを不正に操作して無料で通話を行ったり、ネットワークの脆弱性を利用する技術的な行為を指します。
- 人工知能によって、少ないサンプル数で他人の声や顔を再現することも可能になってきています。



アプリケーション通信

リモートアクセス

● リモートデスクトップコンソールアクセス

RDP (Remote Desktop Protocol)

- デスクトップへのアクセスは、通常TCP5900で実行されるVNC (Virtual Network Computing) とTCPポート3389で通常実行されるRDP (Remote Desktop Protocol) があります。RDPは、Microsoft独自のプロトコルであり、Windowsで使えます。

SSH (Secure Shell)

- コンソールへのリモートアクセスには、TCPポート22を使用します。

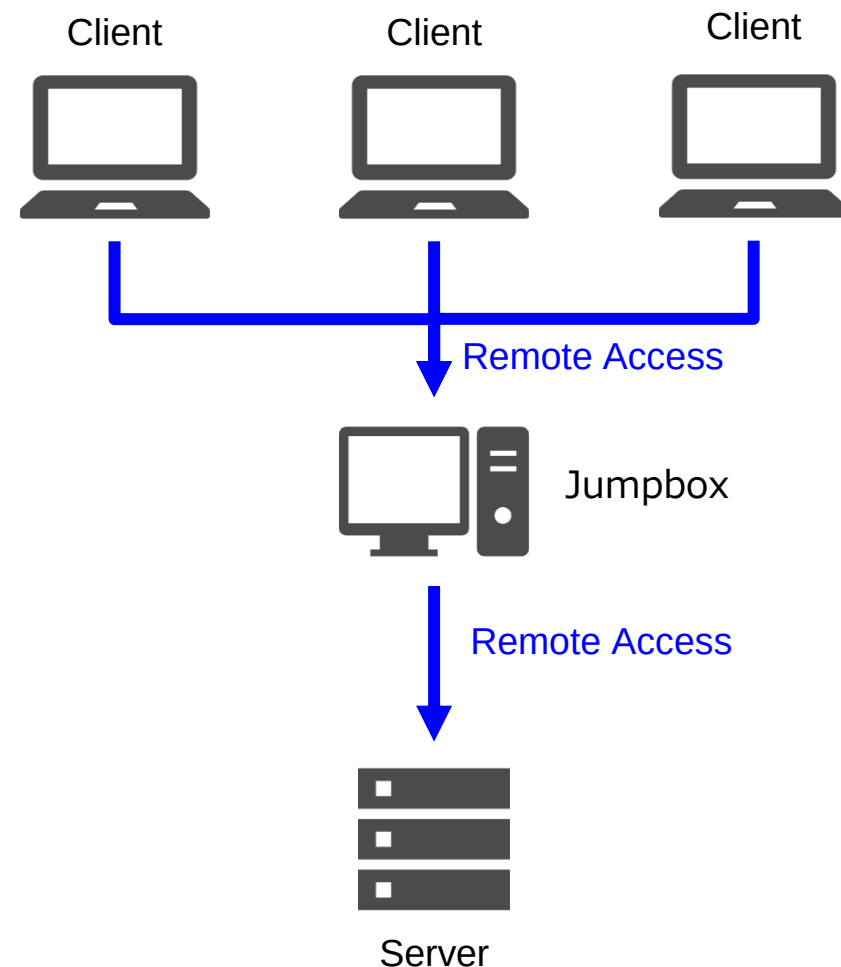
アプリケーション通信

リモートアクセス

● サーバー構築のためのリモート接続

Jumpbox（踏み台サーバー）

- セキュリティ上の目的で使用される中継サーバーで、ネットワーク内部のリソースにアクセスするためのゲートウェイとして機能します。
- 外部から内部リソースへのアクセスは、すべてJumpboxを通して行われるため、アクセス管理がしやすくなります。

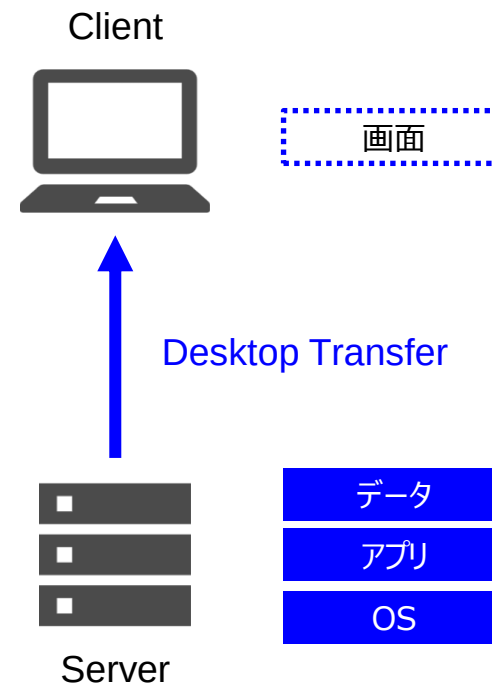


アプリケーション通信

リモートアクセス

●仮想デスクトップ基盤（Virtual Desktop Infrastructure）

- ・ ユーザーが使用するデスクトップ環境（OSやアプリケーション、データ）を仮想化し、中央のサーバー上で管理・提供する技術のことです。
- ・ VMware HorizonやCitrix Virtual Apps and Desktopsといった製品が展開されています。
- ・ VDIは、データ自体をクライアント端末に保持せず、各種ソフトウェアの追加や更新などのメンテナンスが容易になるメリットがあります。
- ・ シンクライアント（Thin Client）とは、必要最小限の機能しか持たないコンピューター端末のことです。ほとんどの処理をサーバー側で行い、クライアント側（ユーザーが使うデバイス）では、入力や表示などの簡単なタスクだけを処理します。
- ・ ゼロクライアント（Zero Client）とは、シンクライアントよりもさらに簡素化された端末で、端末側にほとんどの機能や設定を持たず、すべての処理や管理がサーバー側で行われるデバイスのことです。



アプリケーション通信

エンドポイントセキュリティ

● Anti Virus Software

- ・ コンピューターやネットワークに侵入するウイルスやマルウェアを検出し、除去するためのセキュリティプログラムです。
- ・ コンピューターが動作している間に、ファイルやプログラムが実行されるたびにスキャンを行い、マルウェアを即座に検出して対処します。
- ・ 定期スキャンによって、感染している可能性のあるファイルや領域を見つけ出します。
- ・ アンチウイルスソフトウェアは、新しいウイルスやマルウェアに対応するために、定期的にウイルス定義ファイル（シグネチャ）を更新します。



アプリケーション通信

ウェルノウンポート

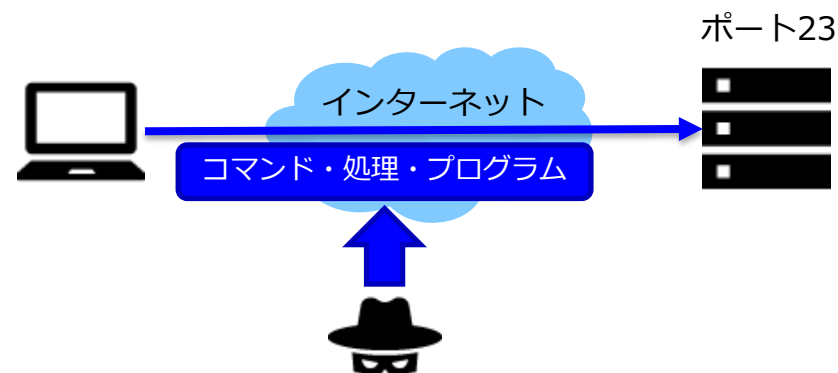
● Telnet

- TCPポート23で実行されるネットワークを介した端末エミュレーションを提供します。
- Telnetサーバはユーザー名とパスワードで認証しますが、送信されるすべてのデータは平文であり機密性はありません。
- SSH、Secure Shellは、セキュリティ認証、機密性、整合性を提供するため、Telnetの代替品となります。

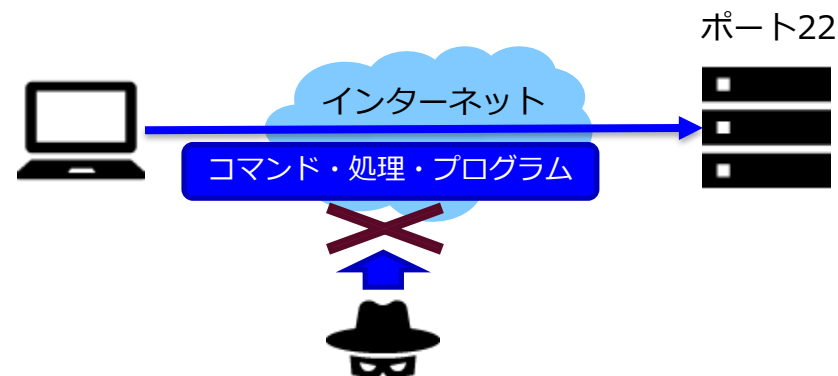
● SSH (Secure Shell)

- TCPポート22で実行される安全な端末エミュレーションを提供します。
- 端末に接続するとき、接続端末・ユーザーへの認証として、パスワード認証方式と公開鍵認証方式が用意されています。

Telnetは操作内容を暗号化せずに実行



SSHは操作内容を暗号化して実行



アプリケーション通信

ウェルノウンポート

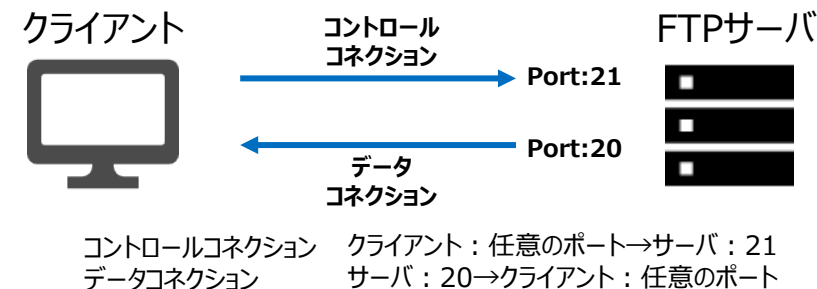
● FTP (File Transfer Protocol)

- サーバーとの間でファイルを転送を提供します。機密性や整合性がないため、安全でない通信経路で使用されません。
- コントロールコネクションのTCP21ポートと、データを送信するためのデータコネクションのTCP20ポートで実行します。
- アクティブFTPでは、アクティブモードを利用するにはクライアントと側のFTPポートを開放するため危険です。パッシブFTPによりアクセス方向を一致させます。

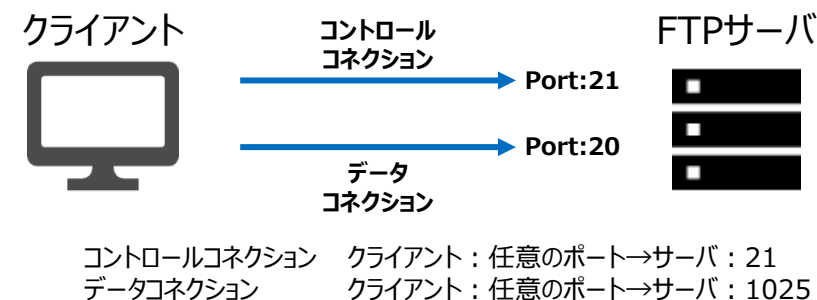
● TFTP (Trivial File Transfer Protocol)

- UDPポート69で実行されるファイル転送プロトコルです。TFTPには認証、ディレクトリ構造がありません。機密性や完全性もありません。
- ファイル転送するための簡単な方法を提供し、ディスクレスワークステーションによるネットワーク経由でのルーター構成の保存または「ブートストラップ」（オペレーティングシステムのダウンロード）によく使用されます。

アクティブFTP



パッシブFTP



アプリケーション通信

ウェルノウンポート

● DNS (Domain Name Service)

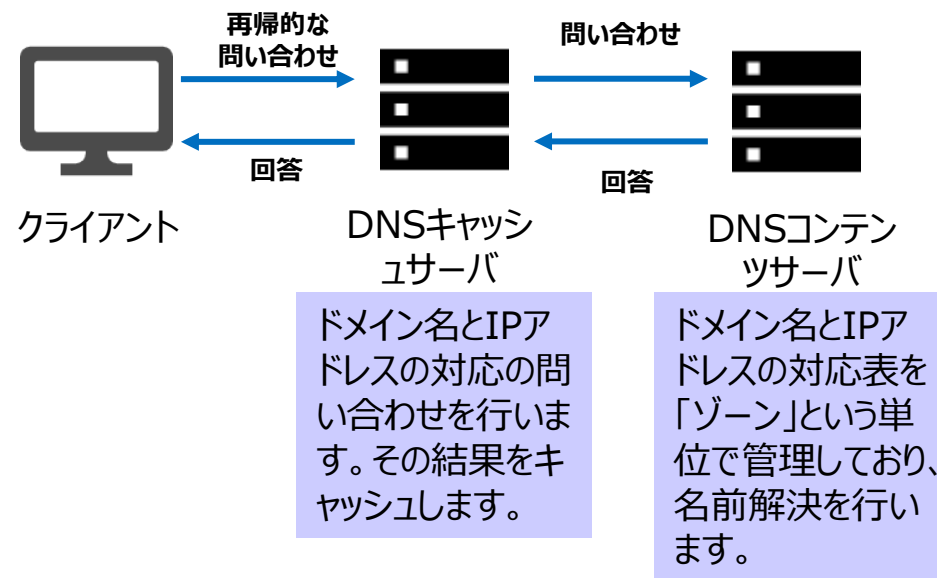
- DNSはドメイン名前解決システムです。DNSはTCPとUDPの両方を使用し、ポート番号53を利用します。
- IPアドレスをドメイン名に変換したり、ドメイン名をIPアドレスに変換する。これを名前解決といいます。

DNSキャッシュポイズニング攻撃 (DNS Cache Poisoning)

- DNS (Domain Name System) サーバーのキャッシュに不正な情報を注入し、ユーザーを攻撃者が制御する偽のウェブサイトへ誘導する攻撃手法です。

DNSSEC (Domain Name System Security Extensions)

- DNS (Domain Name System) のセキュリティを強化するために開発された拡張機能で、DNSデータの改ざんや偽の情報が挿入されるのを防ぐための技術です。



アプリケーション通信

ウェルノウンポート

●SMTP (Simple Mail Transfer Protocol)

- TCPポート25で実行される、サーバー間で電子メールを転送するためにメール転送プロトコルです。

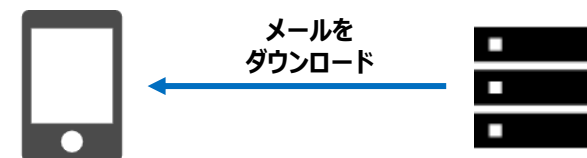
SMTP



●POP (Post Office Protocol)

- TCPポート110で実行される、クライアントサーバー電子メールアクセスプロトコルです。
- メールは端末に保管されますので、既読・未読・削除、フォルダの分類といった管理は、すべて端末のメールソフト（メーラー）が行います。

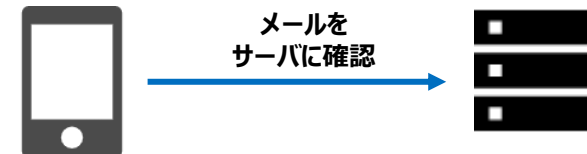
POP



●IMAP (Internet Message Access Protocol)

- TCPポート143で実行される、クライアントサーバー電子メールアクセスプロトコルです。
- メールはサーバーに保管されますので、既読・未読・削除、フォルダの分類といった管理は、すべてサーバー上で行います。

IMAP



アプリケーション通信

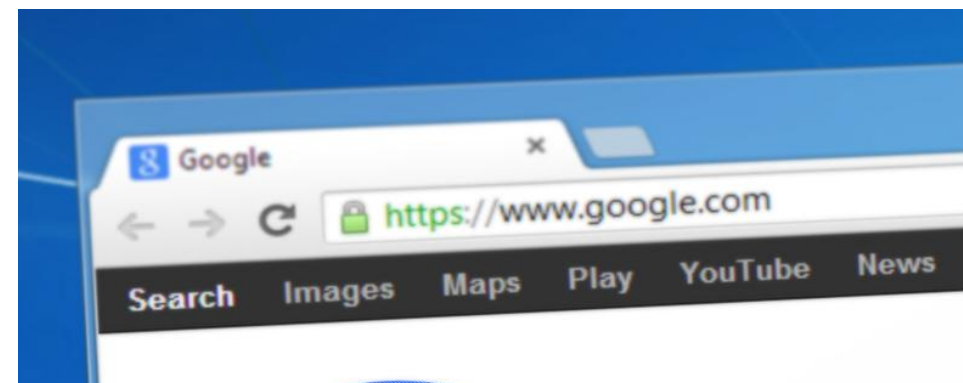
ウェルノウンポート

● HTTP (Hypertext Transfer Protocol)

- TCPポート80を使用し、暗号化されていないWebデータを転送するために使用されるハイパーテキスト転送プロトコルです。

● HTTPS (Hypertext Transfer Protocol Secure)

- TCPポート443を使用し、暗号化されたWebデータをSSLまたはTLS経由で転送します。
- 基本WEBサイトに採用されているべきです。最新のブラウザでは安全ではないWebページでは警告してくれるものもある。

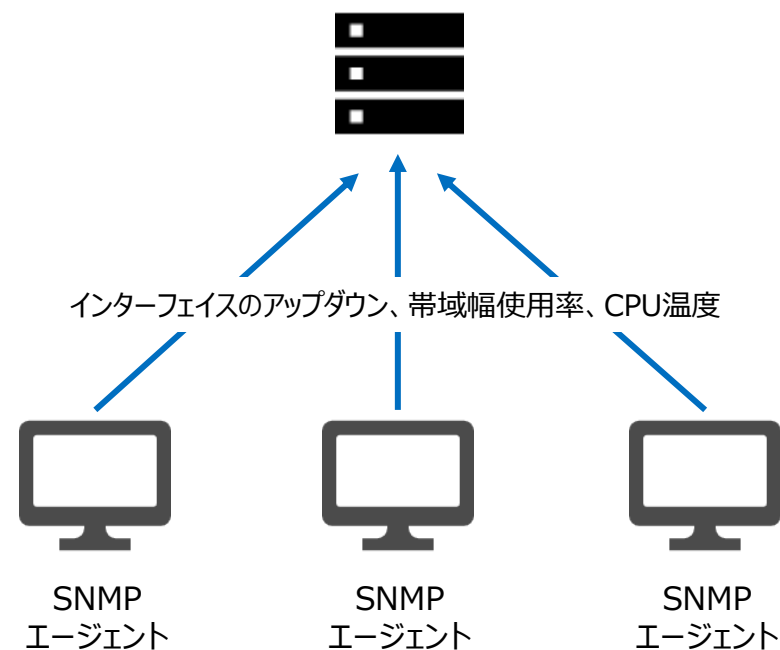


アプリケーション通信

ウェルノウンポート

●SNMP (Simple Network Management Protocol)

- デバイスを監視するためのネットワーク管理プロトコルです。
- SNMPエージェントはUDPポート161を使用します。
- ネットワークデバイス上に配置したSNMPエージェントからインターフェイスのアップダウン、帯域幅使用率、CPU温度などを取得します。
- SNMPv1およびv2は、ネットワークを介して平文で送信されます。そのため、盗聴または推測できてしまうためSNMPv3は機密性や認証機能を持っているためSNMPを利用される際にはv3を推奨します。



アプリケーション通信

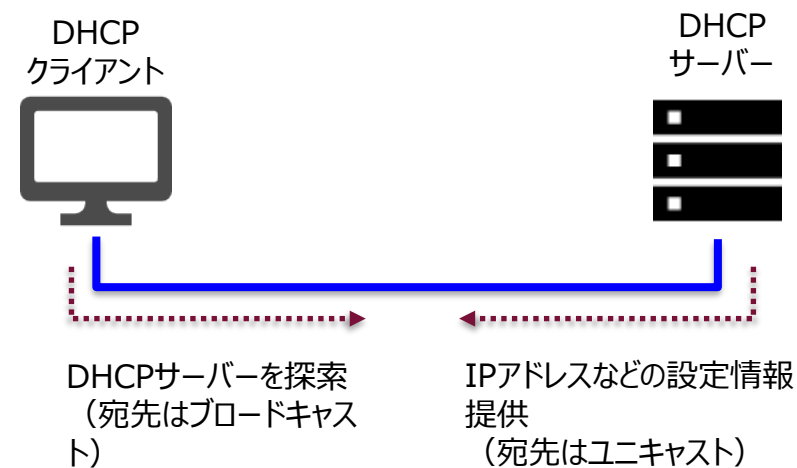
ウェルノウンポート

● BOOTP (Bootstrap Protocol)

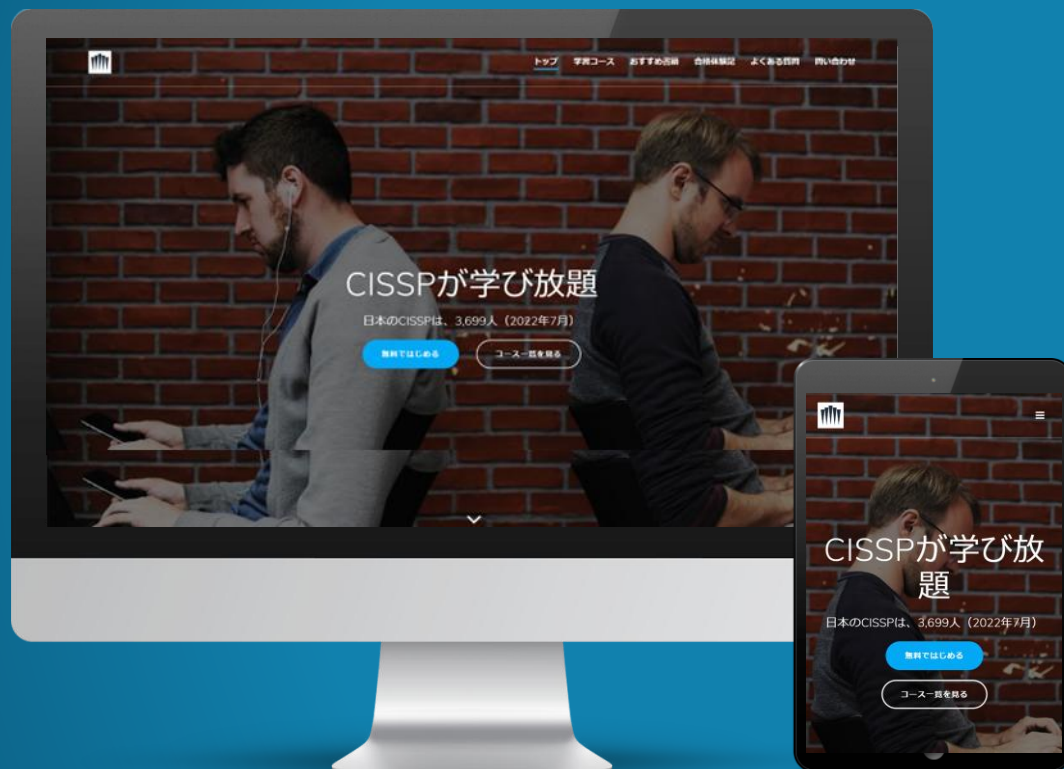
- UDPポート67・クライアントにはUDPポート68を使用し、コンピューターなどの機器がネットワーク上の管理用の機器から自動的にネットワーク設定を取得するための通信プロトコルです。
- ネットワーク経由のブートストラップするためのブートストラッププロトコルとしても利用されます。ブートストラップとは、電源を入れてからOS起動までの一連の動作を指します。多くのBIOSはBOOTPをサポートしているため、デフォルトでネットワーク経由でオペレーティングシステムをロードします。IPアドレスとOSイメージ名を決定し、次にTFTPを使用してオペレーティングシステムをダウンロード行います。

● DHCP (Dynamic Host Configuration Protocol)

- UDPポート67、クライアントにはUDPポート68を使用し、BOOTPと同じ役割を果たし、一時IPアドレスをリースして、端末のIPアドレスとして割り当てることができます。



PIEDPINの紹介



なぜセキュリティを学ぶのか

セキュリティの最も大きな敵は、人はあらゆるものに慣れ、そのリスクを考えなくなる習性にあります。セキュリティの学びを通して得られる貴重なものは、あらゆる事象に対して好奇心を持つことであり、それは目まぐるしい現代を生きるのに大いに役立つでしょう。

- EASY DESIGN
- SUPER EFFICIENT
- EVERYWHERE

PIEDPINを選ぶ理由



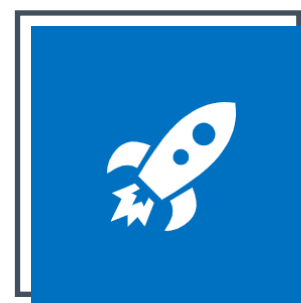
**EASY
DESIGN**

日本語で学べる



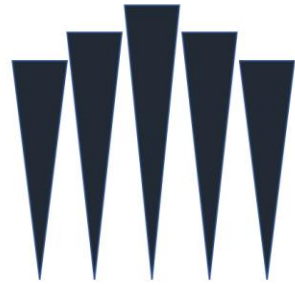
**SUPER
EFFICIENT**

わかりやすい説明



EVERYWHERE

どこからでも学べる環境



THANK YOU

Let's try CISSP!